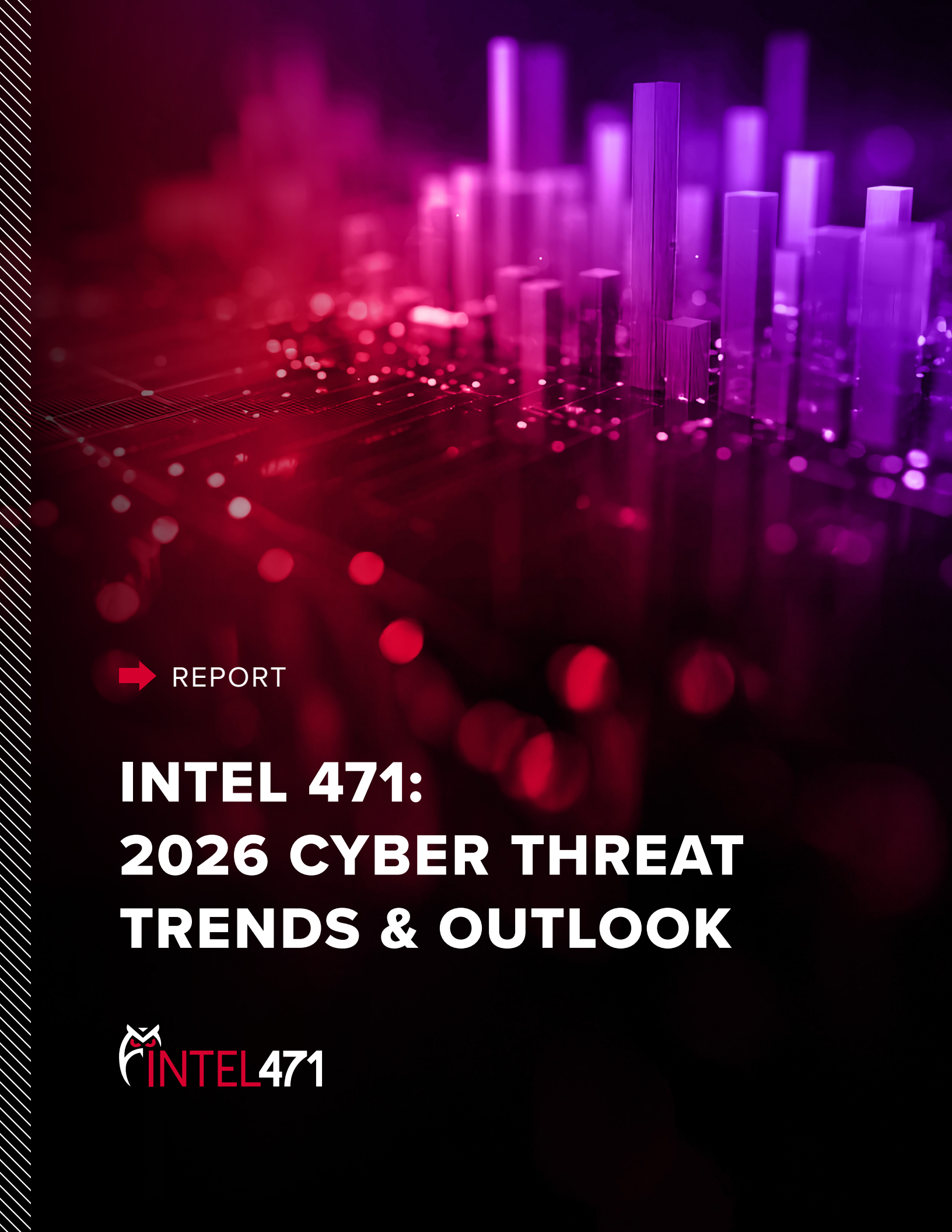




➔ REPORT

INTEL 471: 2026 CYBER THREAT TRENDS & OUTLOOK



Foreword

Welcome to Intel 471's annual threat report: our comprehensive assessment of 2025's cyber threat landscape and a forward-looking view of what these developments signal for defenders in 2026.

The past year exposed a cyber threat economy increasingly optimized for efficiency and scale. Even with significant disruption to cybercriminal ecosystems, we observed adversaries quickly adapt — favoring low-friction delivery methods like ClickFix, using AI to improve speed and quality of their techniques and, most notably, exploiting supply chain compromise to ensure the fastest route to outsized impact.

As a result, 2025 was a year defined by interconnection. Disruption is rarely contained to a single incident. Instead, threat actors capitalize on relationships between platforms, suppliers, identities and the automated processes that modern organizations have come to depend on to move faster and further. Adversaries are adept at refining proven tactics into repeatable playbooks to apply across broader ecosystems, converting single points of trust into outsized downstream impact.

This reality has implications for every organization. Prevention remains essential, but today's measure of success must also include resilience. Leaders must also consider how fast risk spreads, how broadly it can reach and how effectively teams can respond and recover. In 2026, resilience must be engineered across every system and partnership, enabling early identification, rapid containment and confident recovery from the escalating volume of cyber incidents.

Intel 471 acts as your eyes and ears beyond the wire. We surface emerging threats sooner, clarify which exposures matter most in your environment and help you build lasting resilience. We hope this report equips you to make meaningful decisions with confidence in the year ahead.

*Michael DeBolt,
President and Chief Intelligence officer*

Contents

Key Takeaways	6
Introduction	7
Headlines of 2025	8
<i>SP1D3R HUNTERS Gang Sparks Chaos</i>	9
<i>Artificial Intelligence Remains Influential, Not Revolutionary</i>	10
<i>Law Enforcement Action Impacts Multiple Forums and Leads to Fragmentation of English-speaking Underground</i>	12
Extortion	14
Summary	14
Looking Ahead	14
Statistics – Victim Numbers Reach Historic Highs	15
Group in Focus: Qilin	16
Evolution of Tactics, Techniques and Procedures	18
Actors Offer Data Analysis Services to Facilitate Extortion Operations	18
Leaks, Breaches and Takeovers	18
Supply Chain Attacks	19
Outlook	20
Access Offers	21
Summary	21
Looking Ahead:	21
Statistics – Activity Remains Consistent	22
Initial Access Brokers	23
Top Actor – *Black	24
Top Actor – *Gold	25
Initial Access Brokers, Ransomware and Extortion Groups	25
Tactics, Techniques and Procedures Observed	27
Outlook	27
Malware Updates and Developments	28
Summary	28
Looking Ahead	29
Technical Malware Overview	29
Downloader Malware Metrics	30
Malware Downloaded Metrics	31



Mobile Malware Metrics	31
Notable Malware Additions, Updates and Takedown Announcements	32
<i>Campaigns Trends</i>	33
Node Package Manager Supply Chain Attack	33
ClickFix Proliferation.....	34
Outlook.....	37
Vulnerabilities	38
Summary	38
Looking Ahead	38
Vulnerability Statistics Overview	39
Prominent Exploit Brokers	40
Top actor — zeroplayer	40
Top actor — *Bronze	41
Notable Vulnerabilities	41
CVE-2025-5777 aka CitrixBleed 2	41
CVE-2025-53770 aka ToolShell	42
CVE-2025-55182 aka React2Shell	43
Relevant Vulnerability Exploitation Campaigns	43
Outlook	44
Hacktivism	45
Summary	45
Looking Ahead	45
Global Impact of Hacktivism	46
Geopolitical Events Prompting Hacktivism Response	47
Catalysts.....	48
Support to Ukraine	48
Operation Eastwood.....	48
Violence and Humanitarian Crisis in Gaza.....	49
Other Regional Conflicts	50
Notable Tactics, Techniques and Procedures	51
Attacks on Operational Technology Systems.....	51
Outlook.....	51
Predictions for 2026.	52
General Intelligence Requirements.	54
Notes and Disclaimers	56

Key Takeaways

The report that follows is a redacted version of one released to Intel 471 customers on Dec. 23, 2025. It draws on information collected January 1 – December 15, 2025. For full access, including links to related reporting on Verity471, Intel 471's cyber intelligence platform and sensitive source-derived details, contact us at sales@intel471.com.

- The use of artificial intelligence (AI) currently functions more as an efficiency upgrade rather than the core vehicle of operations for profit-driven criminal groups.
- The DarkForums cybercrime forum emerged as the primary choice for English-speaking threat actors in 2025.
- In 2025, **CLOP**, **Qilin** and **SP1D3R HUNTERS** were the most impactful threat groups in operation.
- We reported over 6,800 breach events associated with data extortion intrusions in 2025, an increase of about 63% compared to the previous year, continuing an upward trend that began in 2022.
- In 2025, we observed and reported over 3,200 claims from initial access brokers (IABs) offering to sell unauthorized access to corporate networks or systems, marking a decrease of about 27% compared to 2024.
- In 2025, our telemetry indicated the most downloaded information-stealer malware in descending order were the Lumma, Stealc and Vidar strains.
- In 2025, our Vulnerability Intelligence team reported over 500 vulnerabilities, 238 of which were observed in active exploitation campaigns and more than 80% of these either were weaponized or productized.
- In 2025, we tracked more than 700 responses from hacktivist groups in the cybercrime underground, of which more than 80% were commentary and distributed denial-of-service (DDoS) attacks — evenly distributed at about 40% each.

Please note that an asterisk adjacent to an actor's handle indicates that that handle has been redacted for operational security reasons.



Introduction

The year 2025 marked a period of volatile transformation within the cybercrime underground. The extortion domain was particularly turbulent, characterized by high-profile infighting and the rapid ascension of the **Qilin** group as a dominant threat leader. Simultaneously, the malware market saw a paradigm shift as ClickFix campaigns emerged and subsequently dominated the distribution ecosystem.

Even so, the year's defining narrative was the surge in supply chain vulnerabilities. The **SP1D3R HUNTERS** group incited industry wide panic with its sophisticated breach of the Salesloft customer relationship management (CRM) provider, while the **CLOP** group solidified its reputation as supply chain specialists with two major operations. Finally, AI remained a central concern as its presence became embedded in society and increasingly used by threat actors for efficiency gains.



Headlines of 2025

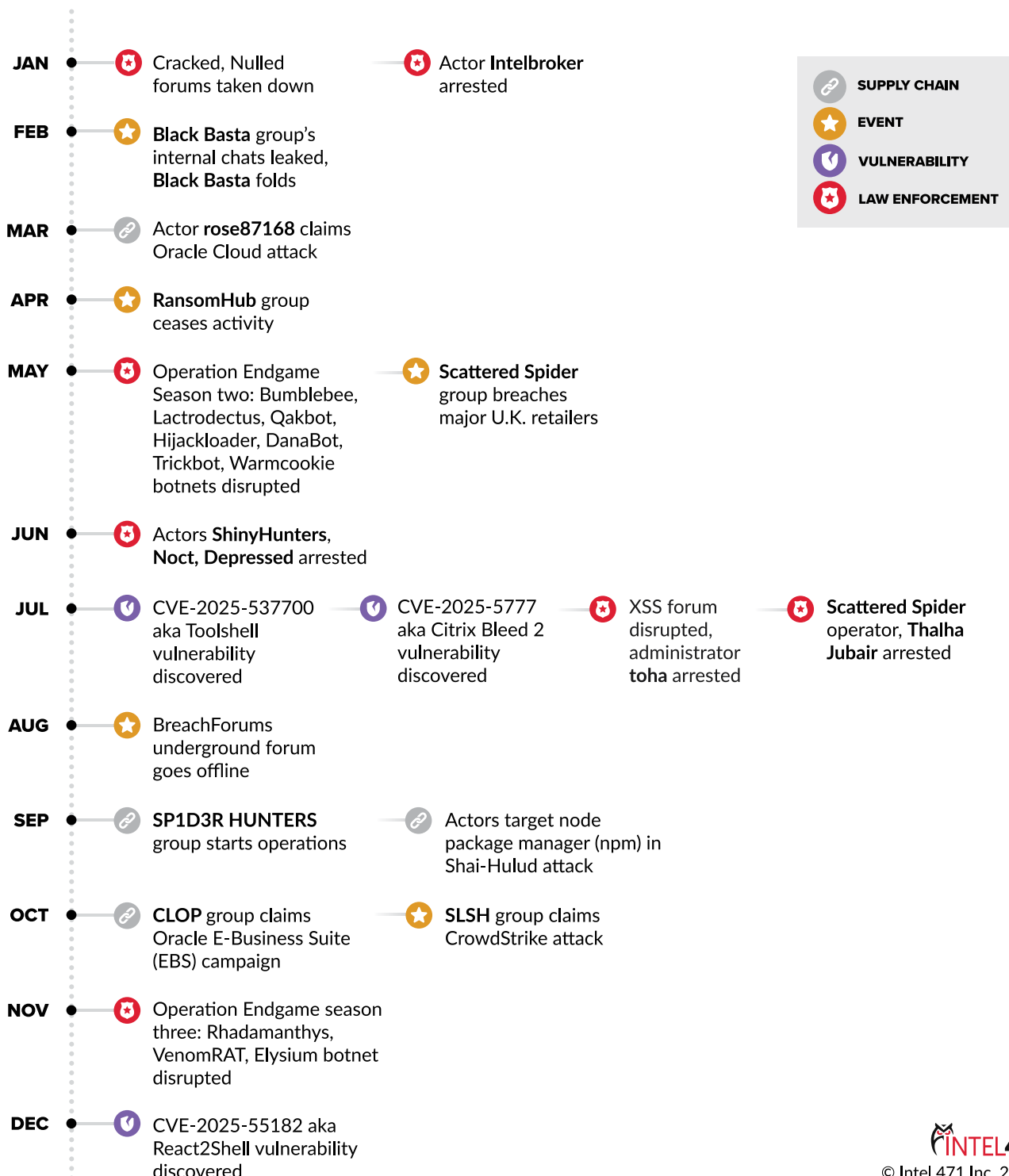


Figure 1: A timeline of key cyber security incidents across 2025.

SP1D3R HUNTERS Gang Sparks Chaos

The English-speaking **Com** aka **TheCom** broad online ecosystem remains a major hub for prominent adversaries. A key development in 2025 was the emergence of the **SP1D3R HUNTERS** aka **SCATTERED LAPSUS\$ HUNTERS**, **SLH**, **SLSH** threat group. The group quickly gained media attention for its aggressive tactics, which included threatening employees of breached organizations as well as anyone who publicly investigated its members. The group evolved into a prolific generator of breach claims, many of which lacked sufficient evidence to be substantiated while others were easily disproven.

Beyond the unverifiable and recycled claims, SLSH was involved in notable breaches. Group members allegedly were in contact with actors involved in breaches impacting the Salesloft and Gainsight platforms – both of which integrate with the U.S.-based technology company Salesforce Inc. – and were directly engaged in multiple social-engineering campaigns that targeted Salesforce customers. Group members demonstrated exploitation capabilities and conducted multiple intrusions that targeted vulnerable SAP NetWeaver and Oracle E-Business Suite (EBS) instances, subsequently leaking the exploit code publicly. The actors also sought to recruit access brokers, insiders and other actors that could collaborate in coordinated crowdsourced extortion campaigns in which participants would send templated extortion emails to lists of targets from breached organizations. Intel 471 successfully identified several of these campaigns in their early stages, with some intrusions becoming public weeks after our initial detection.

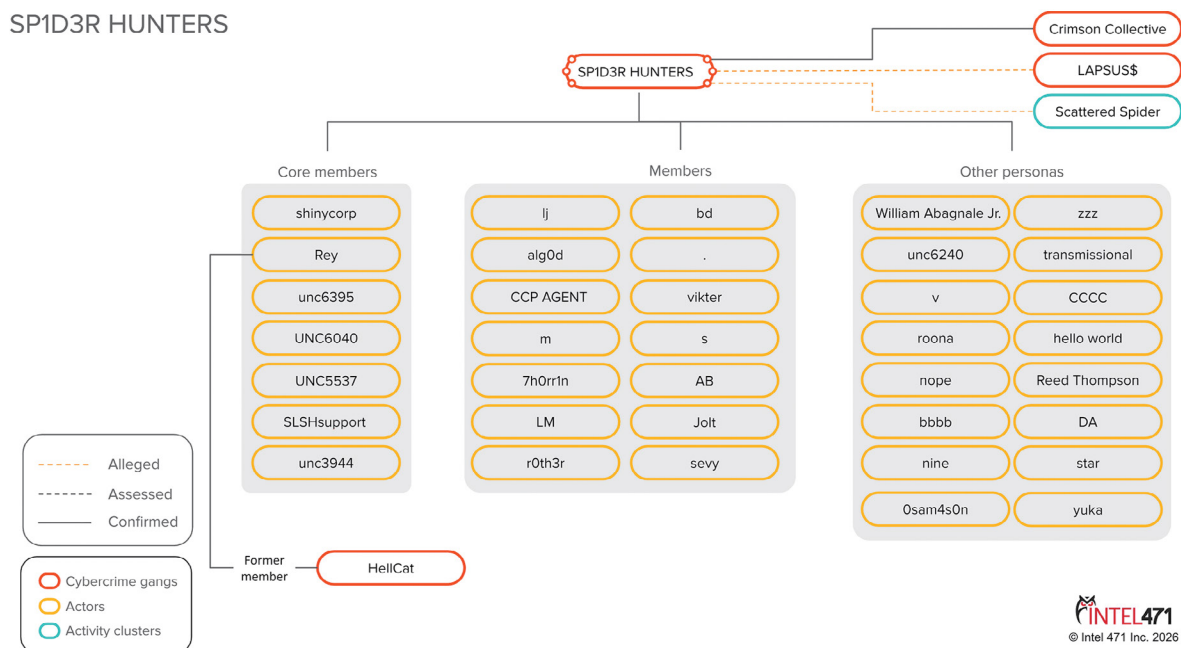


Figure 2: The image depicts a link analysis of **SP1D3R HUNTERS** members and other identified personas created Oct. 27, 2025.

The diversity in the group with multiple members conversing at the same time led to a chaotic environment with thousands of messages that included random topics, offensive language, tasteless memes and evidence of breached organizations. More than 41 different personas were identified posting messages to **SP1D3R HUNTERS'** Telegram channels and groups with about seven identified as core members. Some of these members are reputable actors such as **Rey** — a former **HellCat** group member whose real-life identity was unveiled as the Jordanian individual **Saif Al-Din Khader** — and the actor **unc6395** who was responsible for several threats posted toward cyber threat researchers. The actor **unc639**'s interactions on Telegram provided valuable insights into the actor's bitcoin blockchain activity, enabling the identification of several leads regarding how **unc6395** moved funds, acquired infrastructure and laundered money.

Artificial Intelligence Remains Influential, Not Revolutionary

In 2025, generative AI and large language models (LLMs) continued to be among the most prominent topics of interest within the cybersecurity industry and the underground. Threat actors are adopting LLMs, but this usage is far from the extent often implied in news headlines. In August 2025, we detailed how [generative AI tools have improved the quality](#) of phishing schemes, business email compromise (BEC) lures and voice phishing (vishing) scripts.¹ However, they currently function more as an efficiency upgrade than the core vehicle of operations for profit-driven criminal groups. Although there is limited evidence of AI-driven tools circulating in underground markets, from time to time we do spot offers that claim to integrate AI.

One of [the most recent tools to explicitly advertise AI usage](#) is the InboxPrime AI spamming tool the actor **Mr_Pentium** offered.² The actor allegedly integrated a third-party AI model via an application programming interface (API), allowing the tool to create custom email texts and check crafted emails for potential spam triggers against real spam lists. For example, the integrated AI checks for keywords, suspicious links and unusual hypertext markup language (HTML) formatting and then advises the user on how to improve a message to bypass security measures. Such an implementation boosts efficiency and significantly improves the quality of phishing emails, which often previously were recognizable due to awkward phrasing, spelling errors and obvious copy-and-paste templates. Threat actors can use AI to generate fluent, multilingual and contextually relevant content across various formats — including text, voice, video and images — within seconds.

In addition to phishing, our earlier research has shown AI is proving beneficial for disinformation and influence operations. Actors involved in propaganda — whether state-sponsored or ideologically driven — do not require real-time perfection. Instead, they need

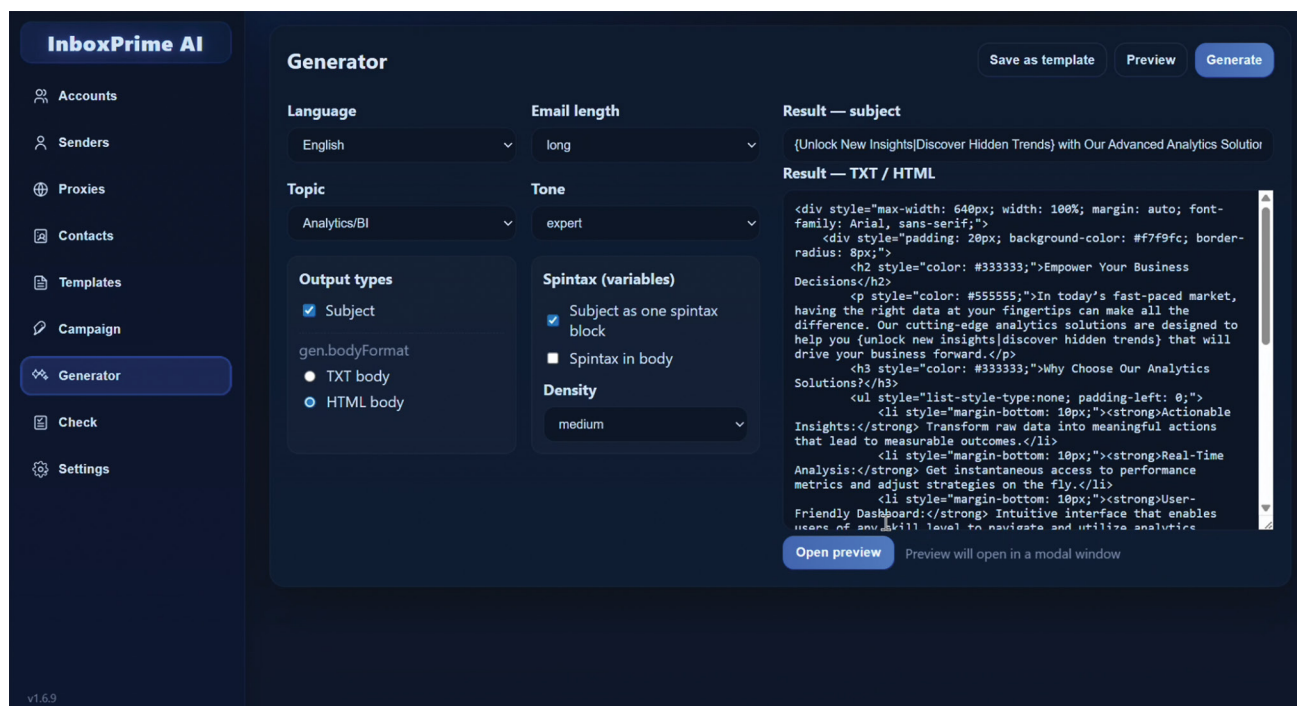


Figure 2: The image depicts a screenshot of the InboxPrime AI tool interface captured from a demonstration video the actor **Mr_Pentium** provided Oct. 30, 2025.

scalability, linguistic reach and a sense of plausible authenticity. Generative text, voice-overs and imagery meet these requirements at minimal cost, allowing small teams to flood channels with culturally tailored narratives, deepfake commentary and convincing videos that previously required professional-grade studios. Since the measure of impact is resonance rather than direct monetization, minor inaccuracies or a higher risk of detection are acceptable trade-offs, making AI a natural accelerator for misinformation campaigns

“AI malware” remains a largely speculative topic. One [vendor report](#) defined AI malware as “malicious or offensive software whose core development or runtime behavior is dependent on generative AI or LLMs.”³ Despite the numerous types of “AI malware” described over the past few years, we have not encountered any widely used malware family, such as loaders or information stealers, that depends on generative AI or LLMs to run. Those presented as featuring “AI malware” are predominantly either proof-of-concept (PoC) artifacts or simply built with the assistance of LLMs. That said, we cannot rule out the possibility that we will see practical examples of fully AI-dependent malware in the future.

However, in both malware and phishing tooling, as long as existing methods work and deliver the expected results, threat actors are unlikely to abandon them for approaches that introduce additional dependencies and development overhead. Training or fine-tuning a private AI model requires considerable time, expertise and resources, and therefore is unlikely to be a first priority for financially motivated actors who want to start making

money as soon as possible with readily available products. For this reason, most of the more advanced experimentation with AI so far has been [attributed to nation-state actors](#) who tend to invest heavily in research and possess the necessary financial and human resources.³ Looking further ahead, we are likely to see selective escalation rather than mass adoption. We expect more deepfake-enabled impersonation calls targeting executives and AI-voiced fraud against high-value targets, alongside a surge in synthetic media during elections, geopolitical flash points and social justice debates.

Law Enforcement Action Impacts Multiple Forums and Leads to Fragmentation of English-speaking Underground

2025 was marked by coordinated international law enforcement efforts severely disrupting primarily English-speaking cybercrime forums (see: Figure 3). In January 2025, [Operation Talent](#) — led by German authorities in collaboration with numerous international agencies — seized the domains of the Cracked and Nulled forums, as well as the Sellix payment platform and StarkRDP hosting service. This action resulted in arrests, property searches and the seizure of substantial assets, permanently shutting down the Nulled forum, although Cracked [reemerged under a new domain](#) in April 2025.^{4,5}

Forum disruptions continued throughout the year, with the BreachForums and XSS cybercrime forums suffering periods of instability and [the arrests of high-profile operators](#) including the actors **IntelBroker**, **ShinyHunters**, **Hollow**, **Noct** and **Depressed**, as well as the XSS forum administrator **toha** aka **admin**. The BreachForums cybercrime forum eventually closed for good in August 2025, while the XSS forum regained stability the same month and continued operation moving forward. The repeated seizures and arrests caused [immense fragmentation](#) in the English-speaking cybercrime community, with users constantly migrating between short-lived successor and clone sites. The DarkForums cybercrime forum emerged as the clear benefactor, however other forums such as BreachStars, Cracked and DarkNetArmy [saw an increase in activity](#), as well as the launch of the new Rehubcom forum.^{6,7,8}

Moving forward, the DarkForums cybercrime forum likely will continue to be the choice for former BreachForums members. While we cannot rule out a potential relaunch of BreachForums under new ownership and perhaps a new name, any such event likely would be met with heavy skepticism and thus fail to dethrone DarkForums. Additionally, we anticipate law enforcement action against prominent cybercriminal infrastructure will continue, and more long-standing forums such as DarkNetArmy and Leakbase could offer English-speaking actors a safe haven should DarkForums suffer any significant disruption.

OBSERVED FORUM ACTIVITY IN 2025

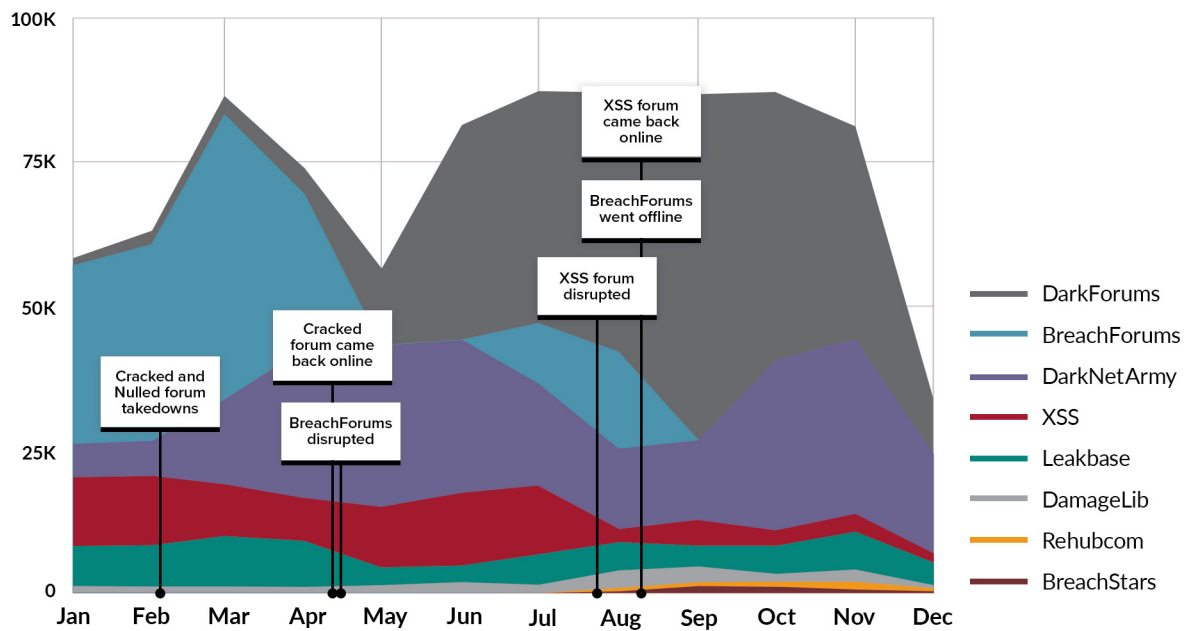
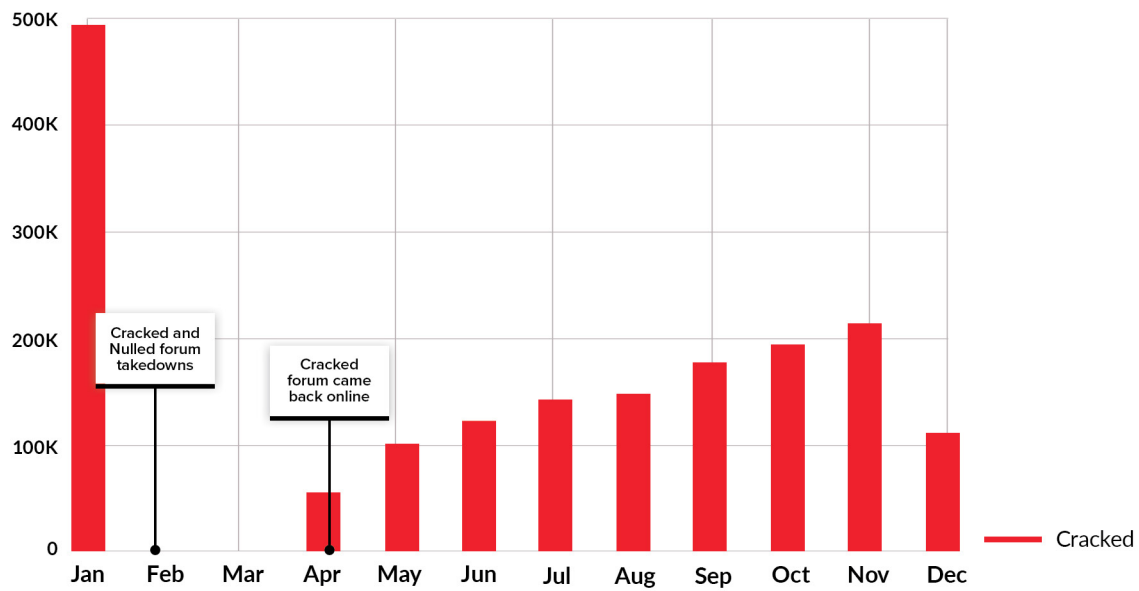


Figure 3: The images depict the amount of posts we observed on each forum per month in 2025.

Extortion

The reporting metrics for this section were sourced from Intel 471 Breach Alerts and Information Reports and are not representative of all extortion instances possibly claimed across the underground.*

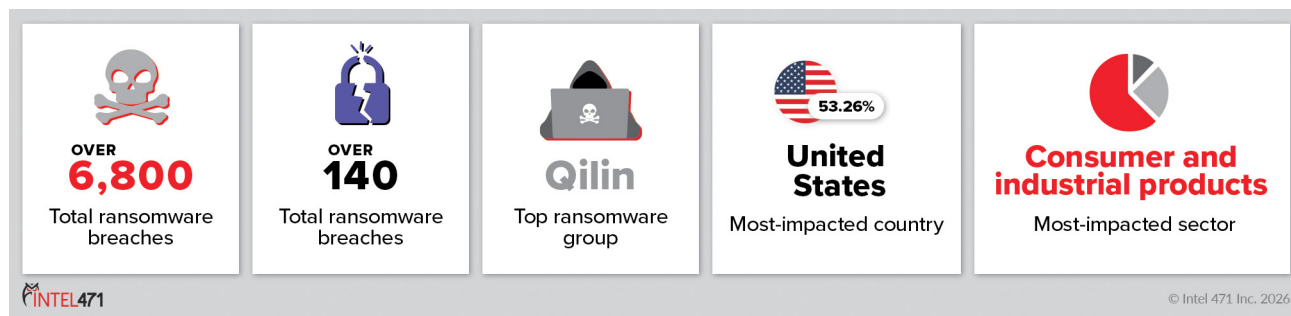


Figure 4: The image depicts top extortion statistics for 2025.

Summary

The Qilin ransomware-as-a-service (RaaS) program was the leading force in the extortion market in 2025, claiming about 18% of all victims. It boosted its program with enhanced tooling and the employment of new sophisticated extortion techniques, including a data analysis audit. Additionally, several RaaS programs including the prominent **Black Basta**, **LockBit** and **RansomHub** groups suffered operational disruption from February 2025 to August 2025, seemingly caused by fellow cybercriminals. This year also was marked by several major supply chain attacks, including **CLOP's** attacks on Cleo Harmony managed file transfer (MFT) software-as-a-service (SaaS) and Oracle EBS instances, the compromise of CRM provider Salesloft Inc. and **Qilin's** "Korean Leak" campaign targeting South Korea-based financial institutions.

Looking Ahead:

- The **Qilin** extortion group remains among the most active groups in 2026.
- Extortion groups likely will diversify their services with data analysis and audit functionality, substantially boosting their overall profitability.

Statistics — Victim Numbers Reach Historic Highs

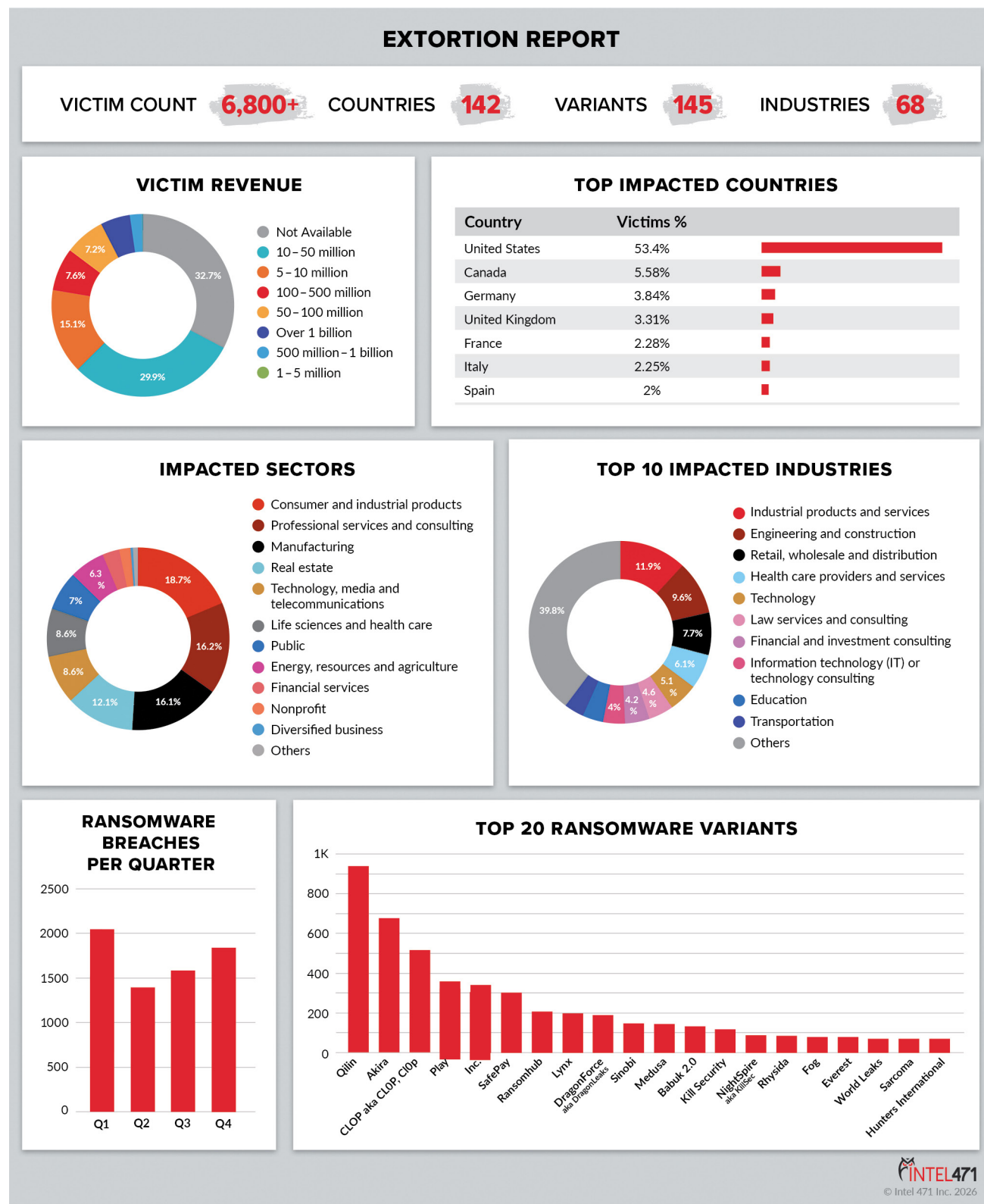


Figure 5: The image depicts an Intel 471-generated graph detailing extortion statistics for 2025.

We reported over 6,800 extortion breach events in 2025, an increase of about 63% compared to the previous year, continuing an upward trend that began in 2022. Throughout 2025, the first quarter saw the highest number of breaches reported, totaling over 2,000. As of Dec. 15, 2025, the number of breaches in the fourth quarter was over 1,800, which already puts it ahead of the second and third quarters with over 1,300 and 1,500 breaches, respectively. Extortion activity first peaked in February with over 800 reported breaches, which likely was driven by **CLOP's** Cleo Harmony campaign. Victim numbers peaked once again in October with over 800 reported breaches, which coincided with the **Qilin** group's increased activity and **CLOP's** second supply chain attack targeting Oracle EBS instances.

Group in Focus: Qilin

The **Qilin** extortion group continues to prove itself a dominant force in the RaaS market. Since its appearance in mid-2022, the RaaS program has continuously evolved, updating its tools and affiliate compensation structures. From mid-February 2025 to mid-May 2025, an operator of the Qilin RaaS affiliate program, the actor **Haise**, [announced major updates](#) to the program.⁹ In June 2025, the group further updated its victim extortion tactics and introduced a “legal department” whose function is to analyze stolen documents for incriminating evidence. The gang also [significantly expanded its extortion capabilities](#) by establishing a dedicated, multilingual “call center” operating in at least seven languages. This center contacts both victim organizations and their customers, indicating a strategic shift toward a broader, international target base.¹⁰

In 2025, the gang was responsible for about 18% of all breaches, leaving its direct competitors — **Akira**, **CLOP** and **Play** — far behind. From claiming only one victim in January 2025, **Qilin's** victim count peaked to an astonishing 212 reported breaches in October 2025. More than 80% of **Qilin's** victims were entities with low or undisclosed revenues, which suggests the group prioritizes targets that may be easy to attack but likely will pay a minimal ransom. The group's rise in prominence coincided with the demise of the RansomHub RaaS in April 2025 when **Haise** developed a greater presence on the RAMP forum and was [observed actively recruiting new affiliates](#) to the Qilin RaaS. This further demonstrates the group's appealing cooperation terms and high reputation among other extortion groups.¹¹

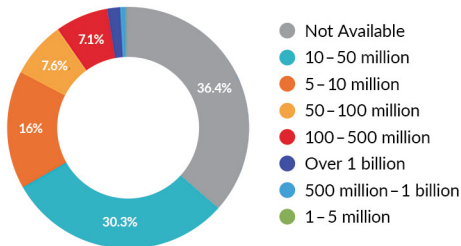
EXTORTION ACTIVITY: Qilin

VICTIM COUNT **900+**

COUNTRIES IMPACTED **70**

INDUSTRIES **52**

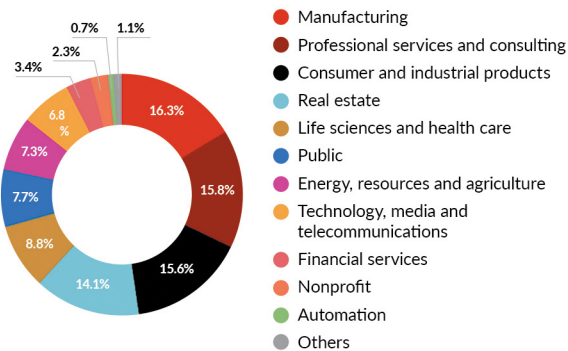
VICTIM REVENUE



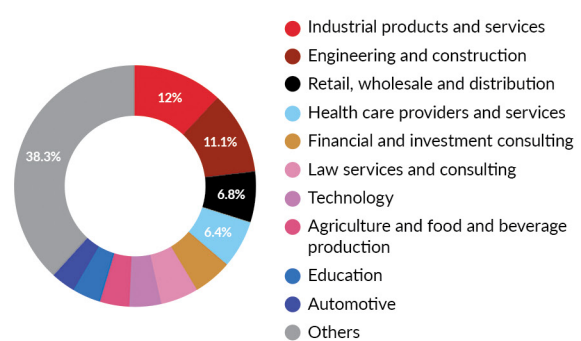
TOP IMPACTED COUNTRIES

Country	Victims %
United States	53.76%
Canada	5.73%
France	5.3%
South Korea	3.92%
Spain	3.18%
Italy	2.76%
United Kingdom	2.76%

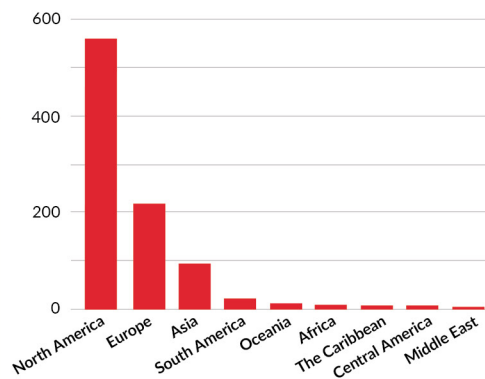
IMPACTED SECTORS



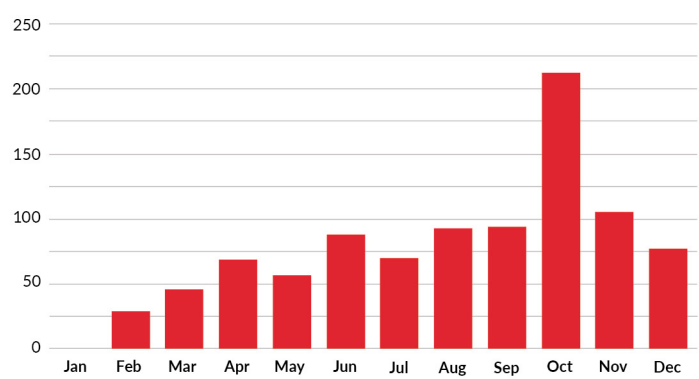
TOP 10 IMPACTED INDUSTRIES



REGIONS IMPACTED



ACTIVITY PER MONTH IN 2025



INTEL471
© Intel 471 Inc. 2026

Figure 6: The image depicts an Intel 471-generated graph of the Qilin group's extortion activity from January 2025 to December 2025.

Evolution of Tactics, Techniques and Procedures

Actors Offer Data Analysis Services to Facilitate Extortion Operations

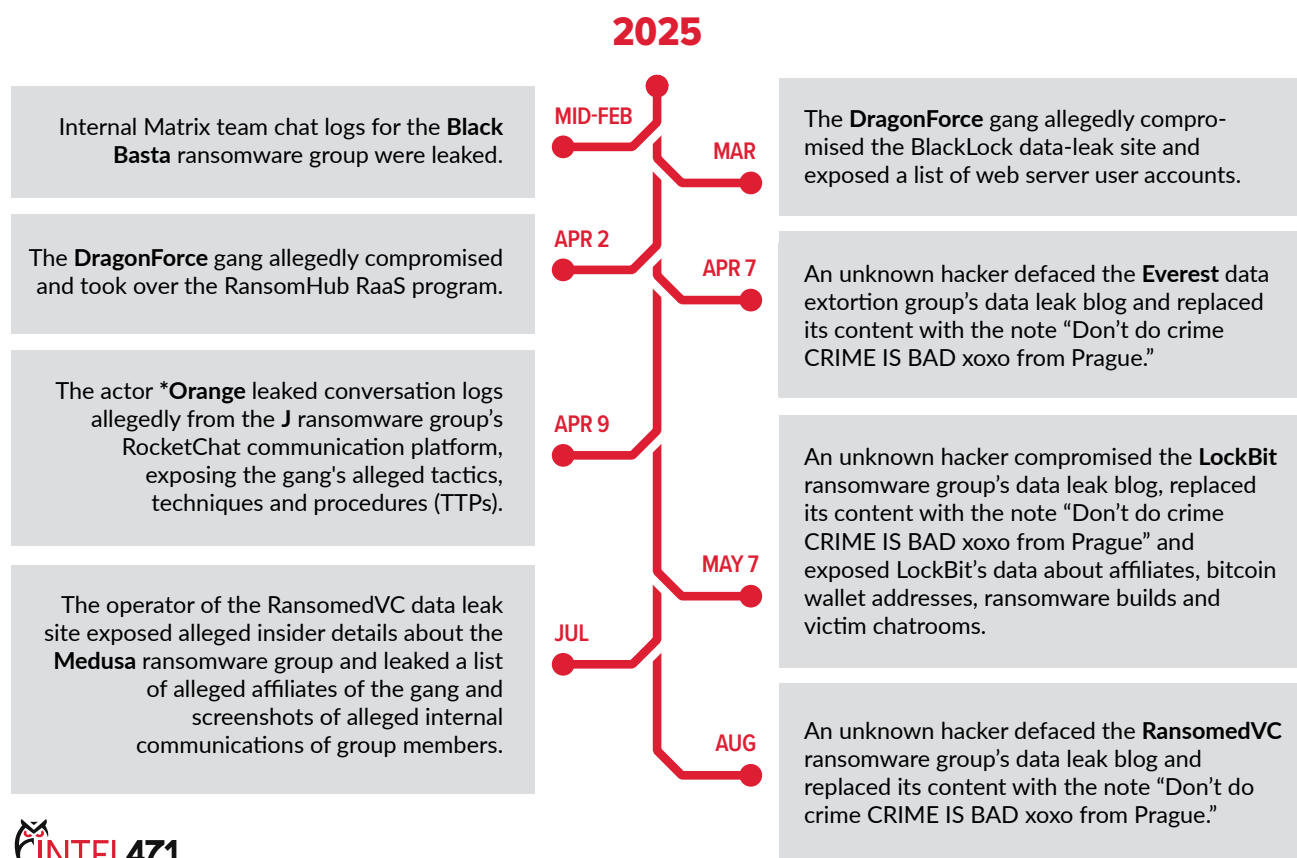
In the second quarter of 2025, we reported at least two actors, *Green and *Pink, offered to provide negotiations and data audit and analysis services to facilitate extortion operations. [The actor *Green's offer](#) allegedly included scanning the targeted company's data, pinpointing weaknesses and developing a "presentation" for the victim, while *Pink [marketed services](#) to extortion gangs, ransomware groups and individual operators, focusing on analyzing stolen data and conducting negotiations. The actor boasted using advanced techniques gleaned from data analysis and processing courses.^{12,13}

The requirement for increased pressure tactics likely will become more important going forward given new legislation to combat cyber extortion. In May 2025, the Australian government introduced [new reporting obligations](#) under the Cyber Security Act 2024, which require mandatory ransomware and cyber extortion payment reporting.¹⁴ Additionally, in September 2025, the U.K. government approved [a new legislative strategy](#) aimed at discouraging companies from making ransomware payments and enhancing incident reporting.¹⁵ As violations of these regulations can lead to penalties or legal proceedings, companies likely will be reluctant to accept ransomware groups' terms and make payments. Ransomware groups therefore will be forced to actively reconsider their victim extortion procedures.

Leaks, Breaches and Takeovers

Ransomware and extortion attacks have fundamentally reshaped the threat landscape, serving as a hub where diverse cybercrime specialists monetize network compromises. This competitive extortion ecosystem operates without respect or trust. We observed multiple ransomware and data extortion groups betrayed by affiliates or disrupted by competitors or unknown cybercriminals from February 2025 to August 2025 (See Figure 7).¹⁶

Profit-sharing in extortion operations often causes internal and external conflicts, as the lure of financial gain overrides loyalty. This cutthroat environment means reputation is secondary to personal enrichment, leading team members to betray cohorts, jeopardizing operations, exposing data or compromising infrastructure. While disruption can be temporary, it might lead to a group's seizure, which competitors exploit. Demonstrating resilience and power against rivals attracts new affiliates. Conversely, setbacks such as arrests, leaks or internal conflicts make a group vulnerable to competitors recruiting members or taking over systems.



© Intel 471 Inc. 2026

Figure 7: The image depicts the timeline of ransomware and data extortion group compromises in 2025.

Supply Chain Attacks

Supply chain attacks are highly favored by extortion groups due to their superior efficiency, scalability and profitability compared to directly targeting individual organizations. This strategy involves compromising a single entity, such as a vendor, software provider or managed service provider (MSP), to gain access to a multitude of downstream victims. This approach leverages established trust, allowing attackers to bypass robust defenses and achieve a much greater impact with significantly less effort.

The year was bookended by campaigns from the now notorious supply chain-attacking **CLOP** aka **CL0P**, **CI0p**, **CL0P^_- LEAKS** ransomware and data extortion group. The first incident impacted Cleo Harmony MFT SaaS and began in late 2024 before concluding in February 2025. We identified [over 350 corresponding victims](#). The second campaign leveraged a zero-day vulnerability in Oracle EBS and began Oct. 1, 2025. The group claimed 115 victims likely associated with the exploitation of Oracle EBS vulnerabilities as

of Dec. 15, 2025. Entities in the U.S. accounted for more than 63.5% of total victims and the manufacturing sector was the most impacted.¹⁷

In August 2025, one of the year's most notable supply chain campaigns occurred when the CRM provider Salesloft Inc. was compromised. The [widespread campaign](#) began in March 2025 after the company's GitHub account was breached, leading Salesloft customers who had integrated their Drift AI-based chatbot plug-in with the Salesforce platform to be susceptible to data exfiltration from their Salesforce instances. According to an outreach contact, the number of potentially impacted companies in the Salesloft incident possibly surpassed 700. Members of the **SP1D3R HUNTERS** cybercrime group suggested involvement or were in contact with the adversaries involved in the breach but no reliable evidence was available to corroborate the attribution at the time of this report.¹⁸

In September 2025, the **Qilin** group launched a "Korean Leak" campaign primarily targeting South Korean financial institutions. The gang allegedly impacted at least 20 South Korea-based companies, [exposing sensitive information](#) including corporate and financial information as well as employee personal data.¹⁹ The group reportedly executed the attacks by initially compromising a single upstream MSP. [Open source reports](#) indicate more than 20 asset management firms were breached via a common information technology (IT) service provider that supported their internal systems.²⁰

Outlook

We expect extortion to remain the top threat in 2026, which is evident by this year's significant increase of breaches compared to 2024. The demonstrable success of several high-profile supply chain attacks conducted by the **CLOP** and **Qilin** gangs provides a powerful example and likely will influence the strategic focus of other ransomware and data extortion groups. The Qilin RaaS program likely will continue to dominate the extortion market, enhancing its offerings and actively recruiting new affiliates. Finally, the shift in legislation regarding extortion payments likely will reduce companies' willingness to pay ransoms. Therefore, ransomware and data extortion groups likely will reconsider their victim pressure strategies and add new services to their programs.

THE
DEMONSTRABLE
SUCCESS OF
SEVERAL HIGH-
PROFILE SUPPLY
CHAIN ATTACKS
PROVIDES A
POWERFUL
EXAMPLE
FOR OTHER
RANSOMWARE AND
DATA EXTORTION
GROUPS.

Access Offers

The reporting metrics for this section were sourced from Intel 471 Breach Alerts, Information Reports and auction offers made on the Exploit forum.**

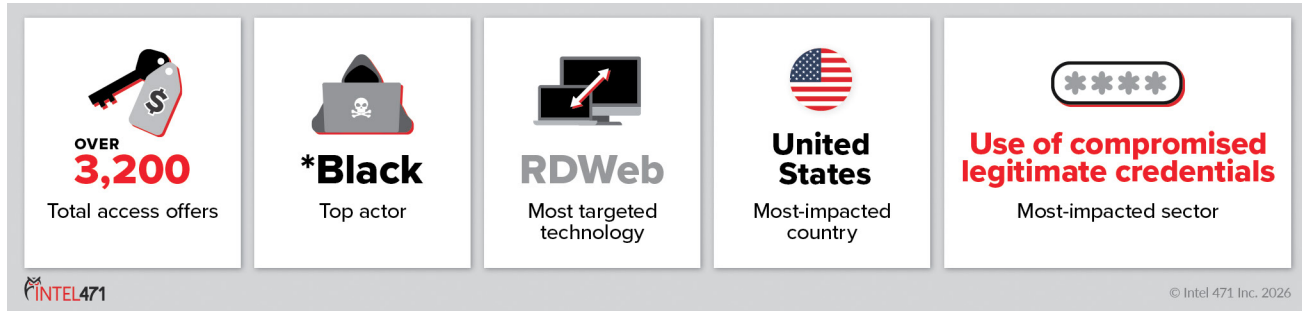


Figure 8: The image depicts top access offer statistics for 2025.

Summary

The year 2025 ends with a decrease of about 27% in the total access offers compared to 2024, characterized by a lack of substantial bulk offers. The most prominent actors ***Black**, ***White**, ***Gold**, **Pirat-Networks** and **samy01** demonstrated their relevance in the access market and accounted for about 40% of all offers. Living off the land binaries (LOLBins) such as nltest and the PowerShell utility constantly were observed in intrusions that involved access brokers to generate proof of compromise for potential customers.

Looking Ahead:

- The access market will remain volatile, characterized by occasional bulk offers and the emergence of new actors, as well as increased professionalization as specified offers become more tailored to potential customers.
- Credential-based intrusions are likely to remain the dominant access vector, while remote access portals will continue to present attractive entry points.

Statistics — Activity Remains Consistent

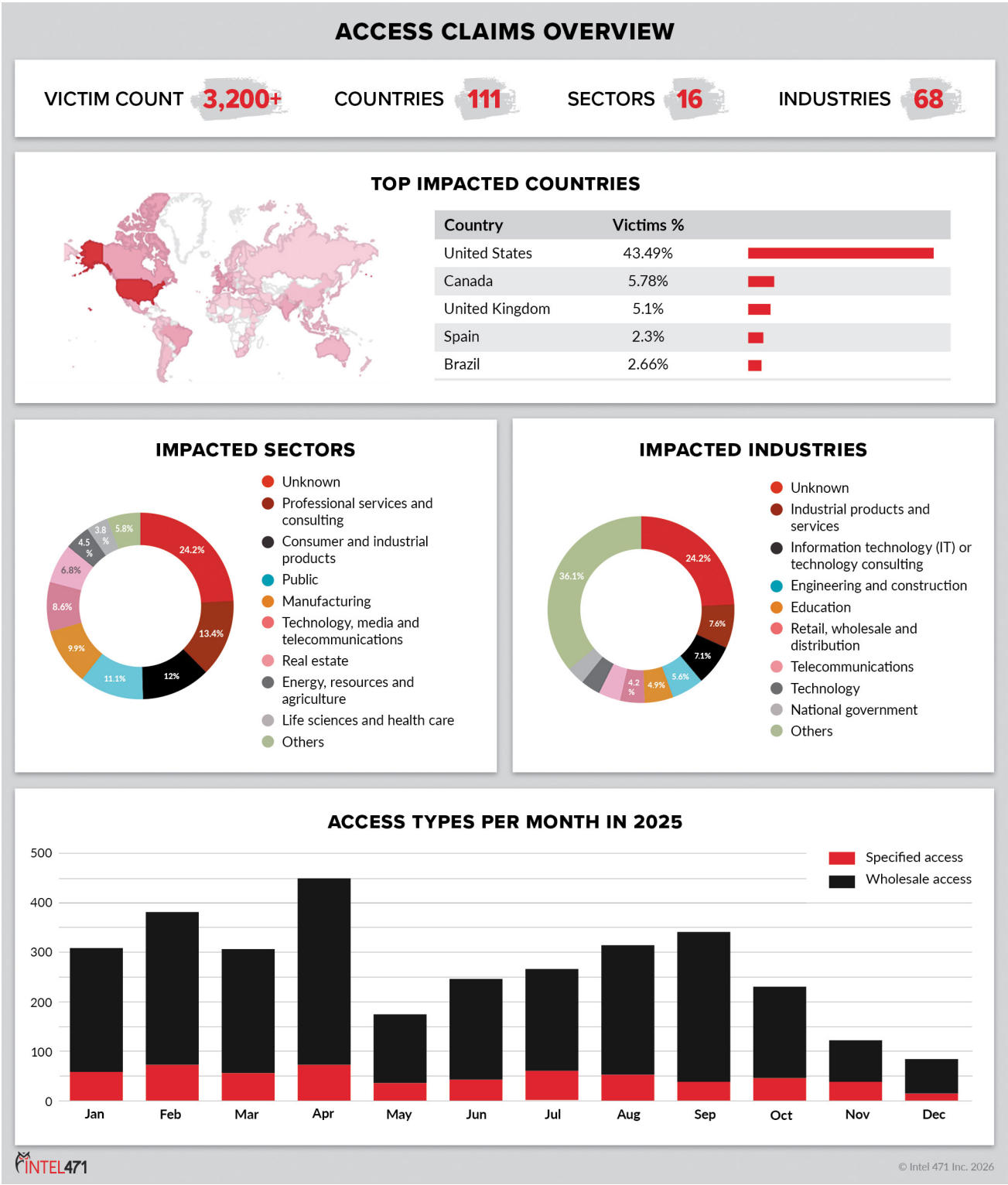


Figure 9: The image depicts the sectors, industries and countries most impacted by all access offers in 2025.

In 2025, we observed and reported over 3,200 claims from IABs offering to sell unauthorized access to corporate networks or systems, marking a decrease of about 27% compared to 2024. The decrease in numbers was expected, as the figures in 2024 were inflated due to bulk access offers originating from supply chain attacks that impacted service providers such as Cprime and Snowflake. Several bulk offers also were observed in 2025 but the lack of substantial evidence was the decisive factor in not including them in the statistics. Looking at the data without considering these specific cases allows us to see that the numbers remained steady throughout the period, with the total number of offers consistently ranging from about 200 to 300 in several months of 2025.

Initial Access Brokers

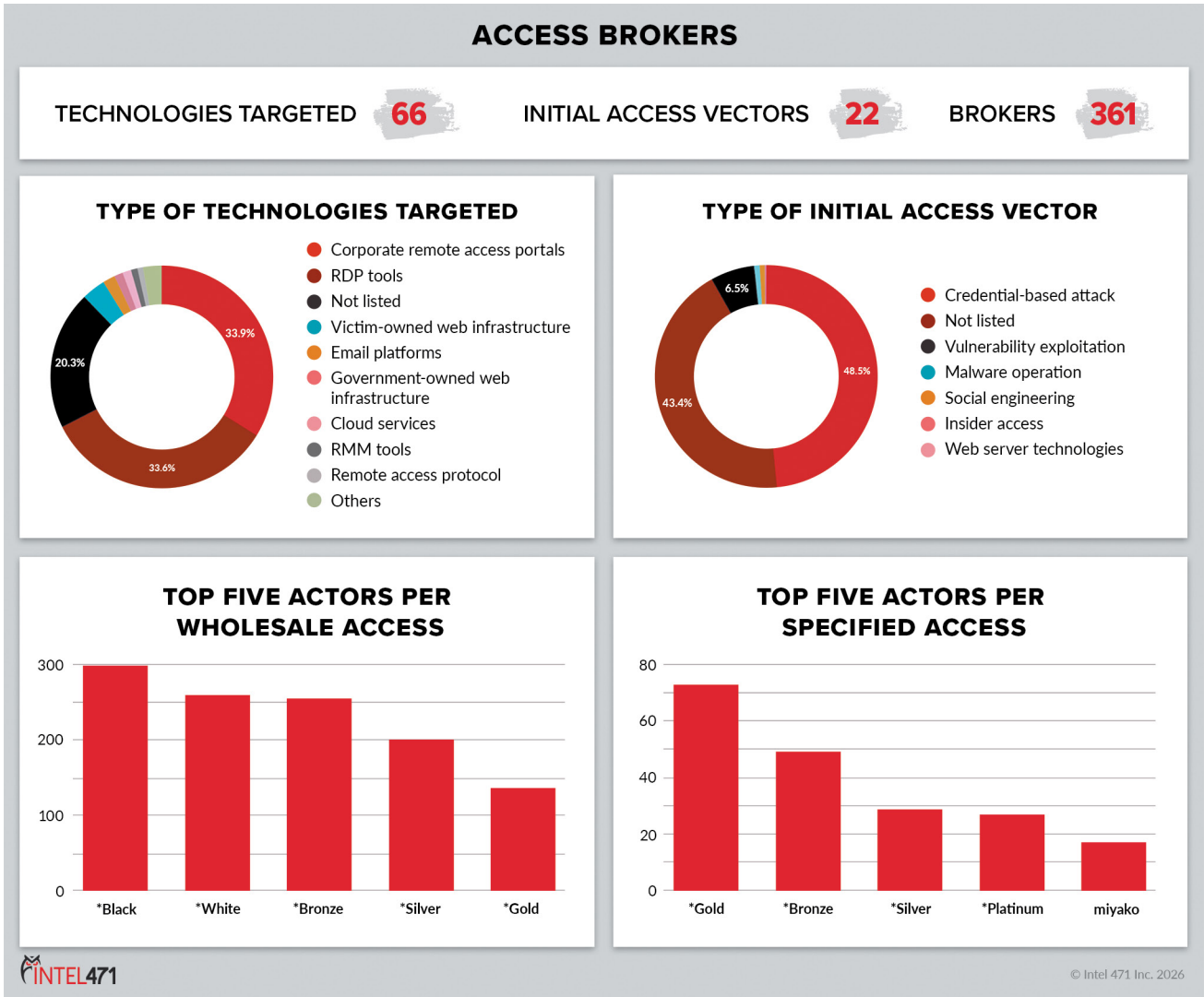


Figure 10: The image depicts the top five actors for both specified and wholesale access offers and statistics for the preferred initial access vector and targeted technology categories observed in 2025.

In 2025, we identified offers from over 360 unique access brokers, over 290 of whom were new and first observed during the year. The actors ***Black** and ***White** were the most relevant in terms of wholesale offers, while ***Gold** and ***Silver** were the most prominent for specified offers, with ***Bronze** holding a notable position across both access types. Together, these five actors represented about 40% of all access offers in 2025. Credential-based attacks accounted for about 49% of all techniques actors used to gain initial access to systems and corporate networks, while remote access portals and remote desktop protocol (RDP)-based technologies were the preferred entry points for breaches, each accounting for about 34%.

Top Actor — ***Black**

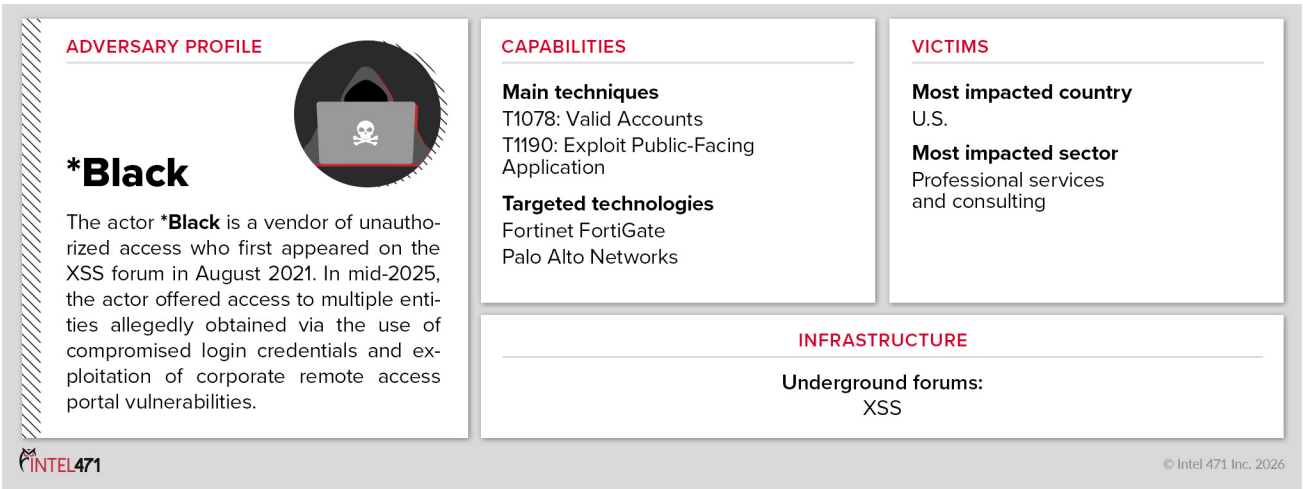


Figure 11: The image depicts an Intel 471-generated graph of the actor ***Black's** Diamond Model profile Dec. 15, 2025.

In 2025, ***Black** was responsible for the highest number of wholesale access offers with almost 300. The actor first appeared on the XSS forum in August 2021 but maintained a low profile on the board. Consequently, much of our insight into ***Black's** activity originates from underground source engagement. Forum interactions indicated the actor was a member of the **Red'n Team** software development group and allegedly is technically experienced with a variety of malicious products, including account-checking tools, bots, brute-forcing utilities, parsers, payload-injection tools, phishing frameworks, plugin installers and scanners. This diverse experience was reflected in the methods used to gain initial access to corporate environments, which typically started with mass scanning of specific IP ranges or countries to identify potentially exposed remote access services. This was followed by brute-force attacks, the direct use of legitimate credentials and the exploitation of vulnerabilities.²¹

Top Actor — *Gold

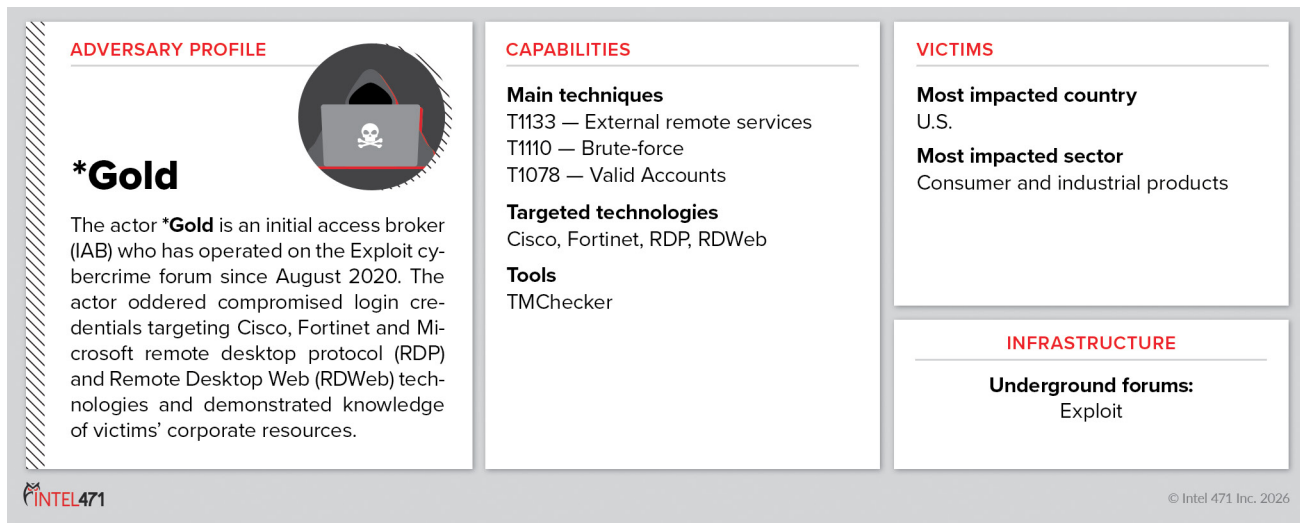


Figure 12: The image depicts an Intel 471-generated graph of the actor ***Gold's** Diamond Model profile Aug. 31, 2025.

In 2025, ***Gold** was responsible for the highest number of specified access offers with over 70 observed. Unlike the low-profile posture of ***Black**, ***Gold's** cadence and forum activity increased significantly, leading the actor to become one of the most impactful access brokers in operation in 2025. The actor's primary method to obtain initial access to victims was via brute-force attacks with support of tools the actors ***Purple** and ***Grey** developed. In 2025, ***Gold** targeted remote access technologies such as Cisco, Fortinet, Palo Alto, SonicWall and Watchguard, as well as Microsoft RDWeb. The actor's advertisement strategy indicated a strong understanding of victim entities, providing detailed information about internal users, endpoint protection software used and the authorization level of compromised accounts. Forum interactions suggested this strategy was successful and garnered attention from high-profile customers such as ***Yellow** — one of the most relevant access buyers in the underground market — and representatives of the Inc. aka INC and Sarcoma RaaS programs.²²

Initial Access Brokers, Ransomware and Extortion Groups

In 2025, we started to identify potential correlations between IAB offerings and victims later claimed by ransomware or data extortion groups. These correlations are preliminary and circumstantial, as they rely on observations from two distinct points in the intrusion lifecycle:

- The early stages, when an access offer becomes available on underground markets.
- The final stage, when a victim is publicly listed on a data-leak site (DLS).

In some instances, we obtain partial visibility into the actors who purchased the access, which provides additional context and strengthens the analytical linkage. However, this visibility is inconsistent and not guaranteed. As such, our assessments are based on a combination of observable facts such as the identification of victim organizations, temporal proximity where we consider a reasonable timeline of about 90 days between an access offer and a victim being claimed publicly, and reasonable analytical assumptions rather than definitive attribution. These correlations therefore should be interpreted as hypotheses informed by available evidence, not as confirmed causal relationships. In these conditions, the top five actors with the most correlations were ***Silver**, ***Maroon**, ***Olive**, ***Gold** and ***Black**. Together, they had possible correlations to 29 different ransomware and extortion groups (See Figure 12).

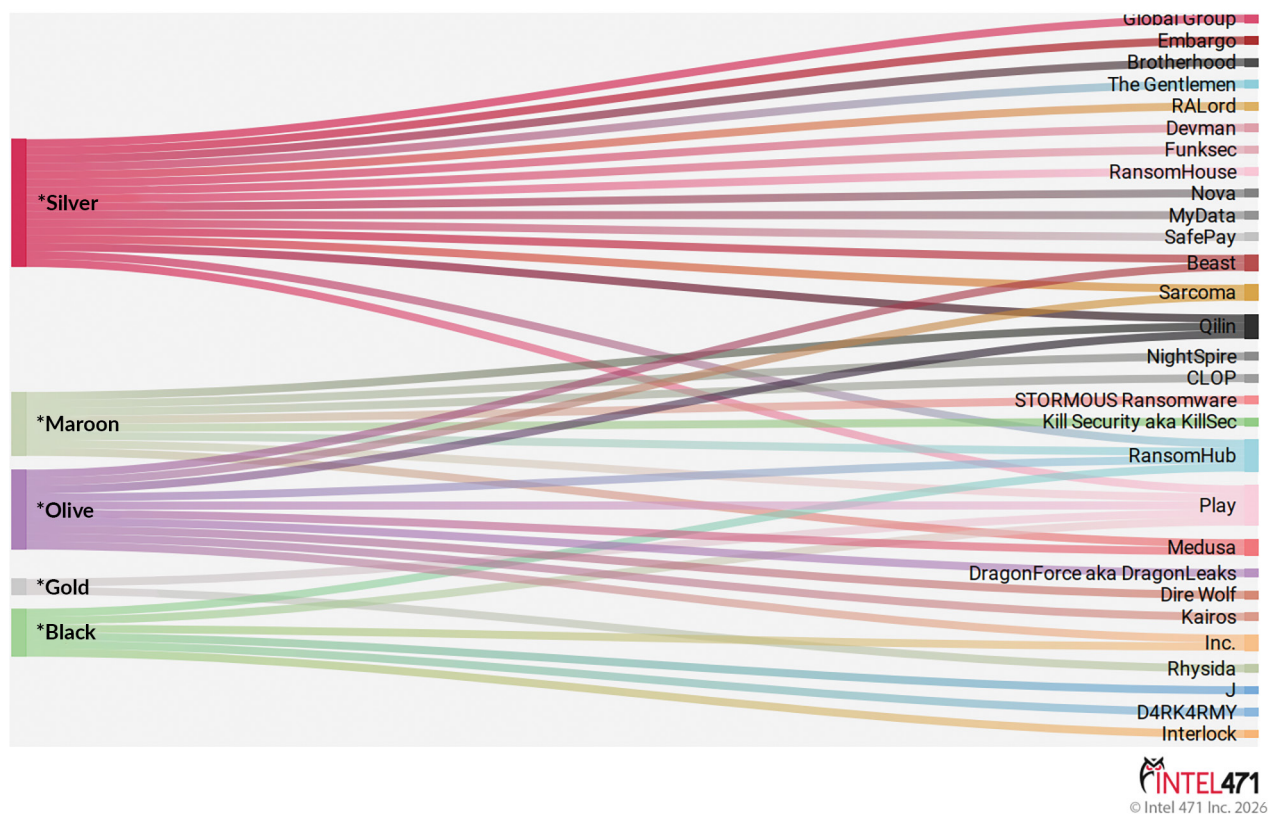


Figure 12: The image depicts a Sankey diagram illustrating the correlation between the top five IABs and victims that ransomware or data extortion gangs claimed in 2025.

Tactics, Techniques and Procedures Observed

In 2025, we conducted an in-depth analysis to identify the most common techniques and procedures used by access brokers, drawing on insights gathered from our sources' engagements with actors in the underground. We observed access brokers tend to rely on a recurring set of tools to demonstrate proof of compromise. From a defender's perspective, understanding the adversary behavior and their tools of preference can serve as early indicators of intrusion activity.

One of the anticipated findings was the [prevalence of LOLBins](#), which are legitimate operating system (OS) utilities that adversaries repurpose to perform reconnaissance, escalate privileges or facilitate lateral movement. Among these, the most frequently observed procedure involved the execution of nltest, a native Windows command-line utility used by system administrators to query domain controllers (DCs) and domain trust relationships.²³

The most commonly observed nltest commands included:

```
nltest /dclist:
nltest /dclist:<VICTIM_DOMAIN>
nltest /domain_trusts
nltest /trusted_domains
nltest /domain_trusts /server:<VICTIM_SERVER>
```

A second frequently observed technique involved the use of PowerShell to enumerate the total number of computer objects within an Active Directory (AD) environment. This behavior surfaced repeatedly in actor engagements and was featured prominently in numerous access offer threads on Russian-language forums where actors advertised their products to demonstrate the value of the target.

Outlook

Moving into 2026, we anticipate the volume of access offers will remain volatile, characterized by occasional bulk offers and the emergence of new actors, as well as increased professionalization as specified offers become more tailored to potential customers. This access market environment was anticipated and confirmed in our last

ACCESS
BROKERS TEND
TO RELY ON
A **RECURRING**
SET OF
TOOLS TO
DEMONSTRATE
PROOF OF
COMPROMISE



annual report, and was evident especially in the number of new access brokers appearing in 2025, which accounted for about 81% of the total. Credential-based intrusions, which accounted for nearly half of all initial access techniques in 2025, are likely to remain the dominant vector, driven by the scalability of credential theft and persistent weaknesses in remote authentication systems. Remote access portals and RDP technologies, each responsible for roughly a third of observed breaches, will continue to present attractive entry points for actors leveraging misconfigurations, weak credentials and inconsistent multifactor authentication (MFA) enforcement.

Additionally, we are preparing for overall improvements in access offer collection in 2026. New insights are anticipated regarding the correlation between access brokers and ransomware and extortion groups, as we identified traceable patterns in the Exploit automated escrow service that allowed us to pinpoint two entities involved in a deal. Simultaneously, we are enhancing our access offer collection capabilities to broaden the scope of technologies and reclassify these offers based on their relevance.

Malware Updates and Developments

*The malware landscape is an ever-changing environment where metrics vary greatly based on several factors.***

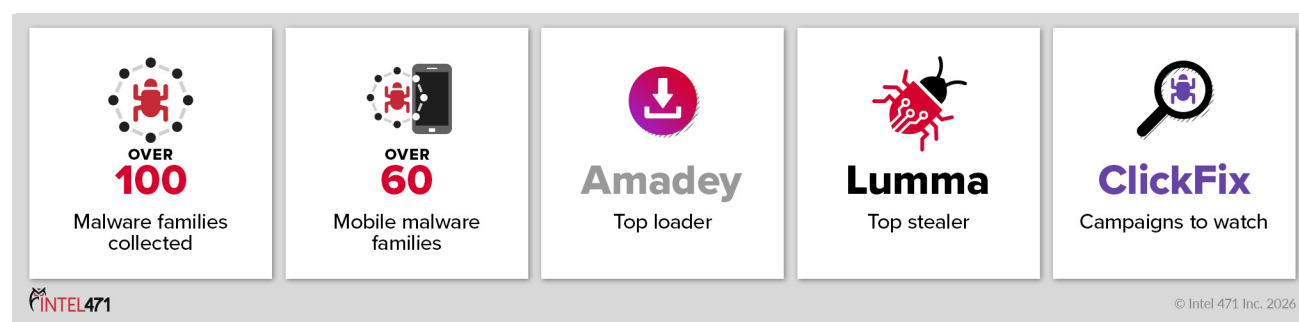


Figure 15: The image depicts top malware statistics for 2025.

Summary

In 2025, malware tactics underwent a significant transformation, with a notable shift toward high-volume social-engineering techniques exemplified by ClickFix. This innovative approach allowed attackers to gain traction in macOS environments by reducing delivery friction and turning execution into a user-driven action. Concurrently, authorities successfully disrupted two major information-stealer operations — Lumma and Rhadamanthys — reshaping the threat landscape and compelling affiliates and buyers to pivot toward other

malware families such as Vidar and Stealc. Additionally, defenders continued to confront persistent challenges stemming from software supply chain compromises, as evidenced by multiple incidents involving node package manager (npm) that disrupted common development workflows.

Looking Ahead:

- ClickFix is expected to maintain its popularity, sustaining high demand for “traffic.”
- We anticipate an increase in supply chain attacks characterized by worm-like automation. These attacks likely will target developer workflows and continuous integration (CI) and continuous delivery (CD) pathways, where execution may occur before standard security checks. This trend will make dependency integrity and identity/credential hygiene more critical than ever.

MALWARE TACTICS
UNDERWENT A
TRANSFORMATION,
WITH A SHIFT
TOWARD **HIGH-
VOLUME SOCIAL-
ENGINEERING**
TECHNIQUES

Technical Malware Overview

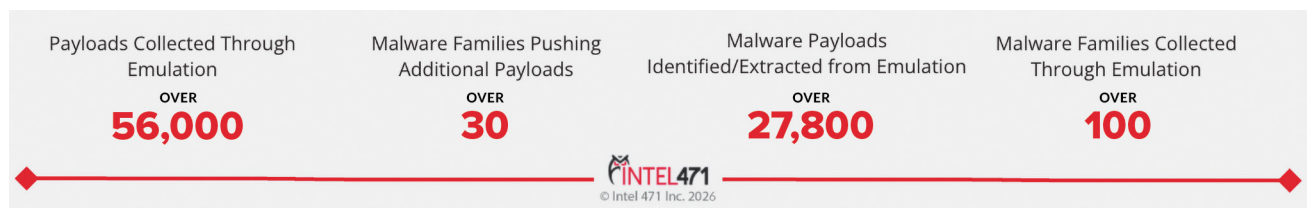


Figure 16: The image depicts the number of payloads collected and identified through emulation, the number of malware families collected and the amount of families pushing further payloads in 2025.

The impact of multiple takedowns, as well as the proliferation of techniques such as ClickFix and malicious advertising (malvertising), contributed to a decline in pay-per-install (PPI) metrics. Both ClickFix and malvertising operate at the traffic layer, focusing on clicks and conversions rather than installs, and therefore cannot be monitored through malware emulation like PPI can.

Downloader Malware Metrics

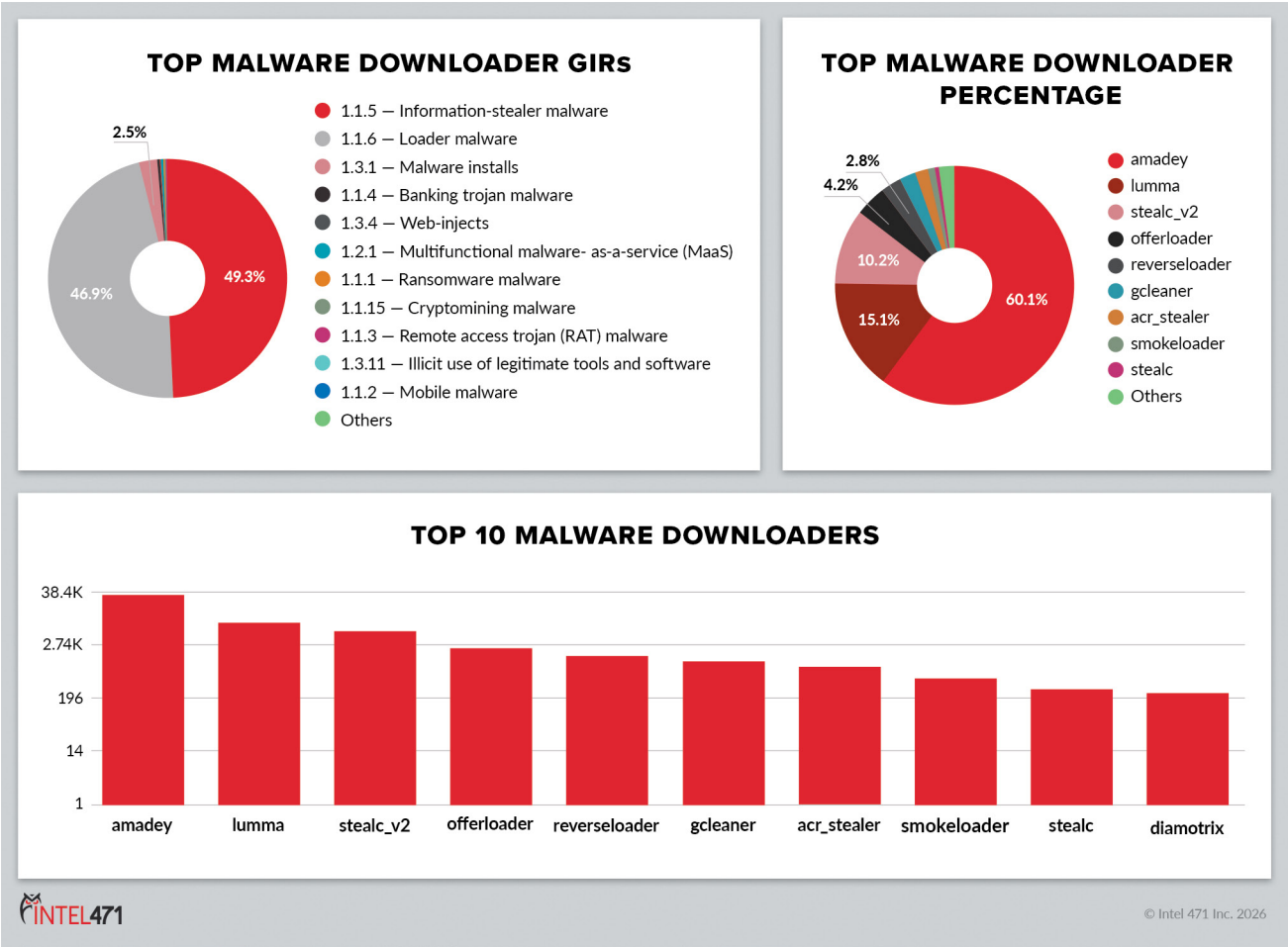


Figure 17: The image depicts the most active downloader malware variants and their percentage of the total monitored in 2025.

The most popular malware families used as first-stage loaders this year can be seen in the graphic above, many of which are dispersed by install services. Tracking these malware families allows us to quickly collect and identify new or updated malware builds that malware operators pay these install services to disseminate. The most popular tools this quarter supporting the aforementioned install services in descending order were the Amadey, Lumma, Stealc_v2 and Offerloader strains.

Malware Downloaded Metrics

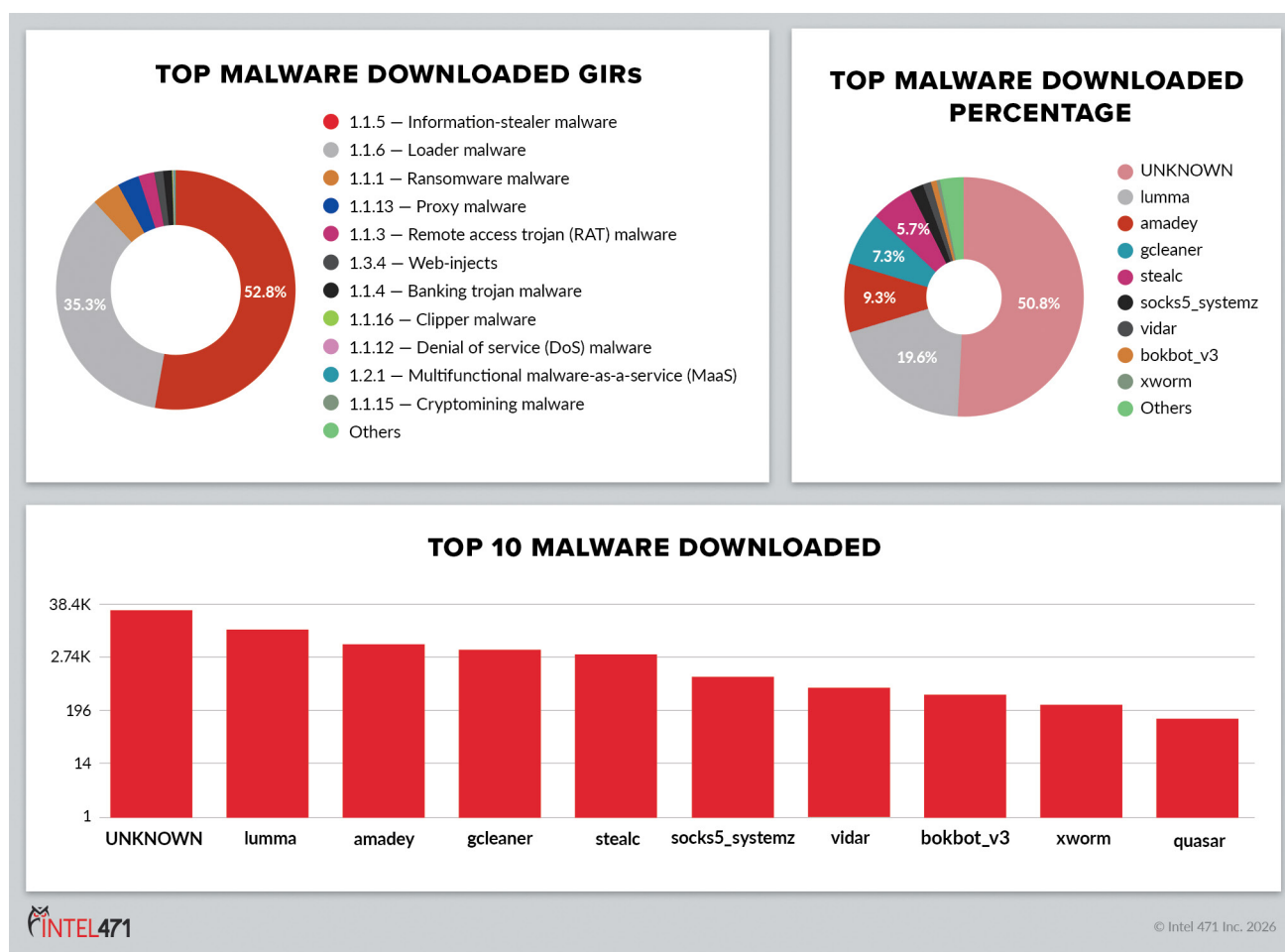


Figure 18: The image depicts the most frequently downloaded malware variants and their percentage of the total monitored in 2025.

Threat actors also continue to leverage loading malware to deliver additional malware payloads, which typically are designed to have an impact on the victim. Information stealers likely feature prominently due to an increasing demand for malware logs and the access credentials derived from them. The most downloaded information-stealer malware in descending order were the Lumma, Stealc and Vidar strains.

Mobile Malware Metrics

From April 1, 2025, to Dec. 1, 2025, our systems identified over 8,400 new observations spanning over 60 distinct mobile malware families. The most prevalent families were SpyNote, Antidot and AhMyth. SpyNote remained dominant with over 4,000 detections — 47.4% of the total — indicating sustained, widespread deployment corroborated by recent open source reporting. Antidot and AhMyth accounted for 8.0% and 7.2% of detections,

respectively. Other notable families included Coper at 4.6%, AndroRat at 3.3% and ShellRat at 2.8%.

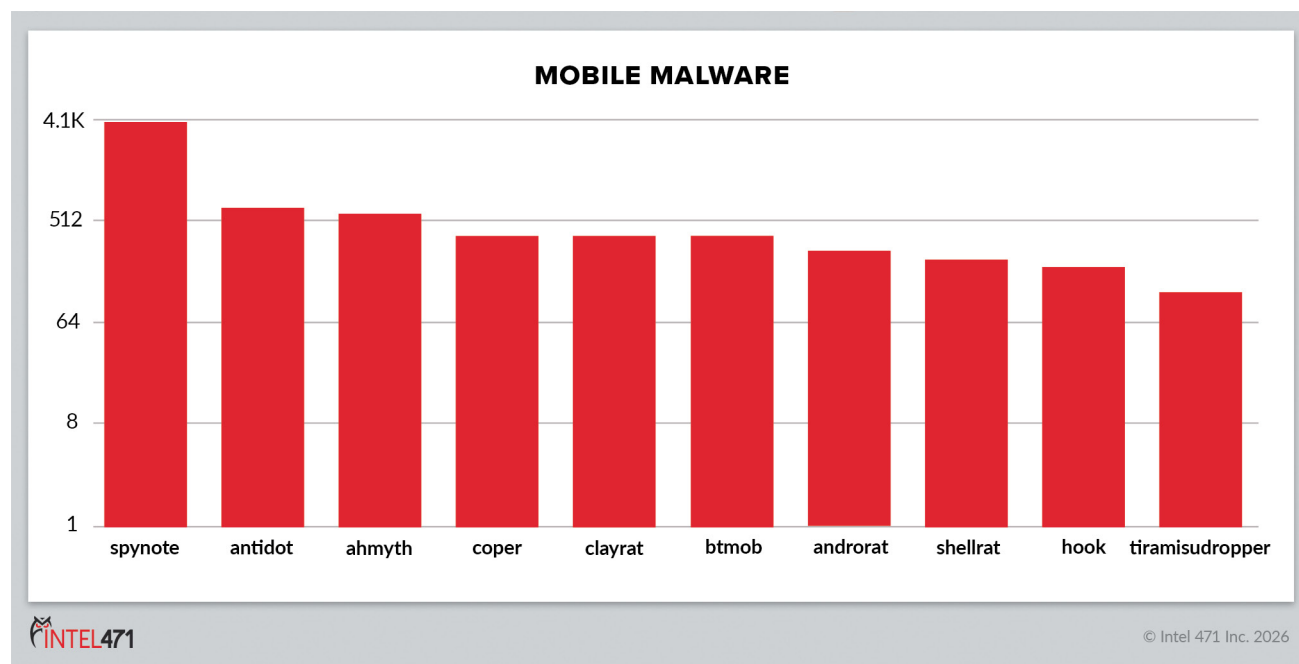


Figure 19: The image depicts a graphic of the most prevalent mobile malware families in 2025.

Notable Malware Additions, Updates and Takedown Announcements

Date	Update
Jan. 7, 2025	Intel 471 Malware Intelligence analysts observed samples of a new Android remote access trojan (RAT) dubbed CyberRat . ²⁴
Jan. 21, 2025	Intel 471 Malware Intelligence analysts observed a sample of a new Android banking trojan tracked internally as MeteorBot . ²⁴
Feb. 27, 2025	Acreeed aka ACR_stealer was added to the Russian Market, a well-established platform used widely by Russian-speaking cybercriminals and other threat actors. ²⁵
March 4, 2025	Intel 471 Malware Intelligence analysts detected a sample of an Android banking trojan later dubbed TsarBot . ²⁶
April 2, 2025	The release of Stealc version 2.0 was announced on the XSS forum. ²⁶
April 3, 2025	The Rhadamanthys information stealer was added to the Russian Market . ²⁶
May 22, 2025	The European Union Agency for Law Enforcement Cooperation (Europol) announced a coordinated action targeting infrastructure supporting the Lumma information-stealing malware. ²⁷

Date	Update
May 23, 2025	Europol announced a coordinated action targeting infrastructure used by the Bumblebee, Lactrodectus, Qakbot aka QBot, Hijackloader, DanaBot, Trickbot and Warmcookie botnets. ²⁷
June 2025	A fork of the GorillaBot botnet emerged under the name ReaperStress , closely replicating the original GorillaBot website. ²⁸
July 15, 2025	A major update to the SmokeLoader malware was announced. ²⁸
September 2025	Rhadamanthys version 0.9.2 was released, featuring a “Lumma-like” message box, portable network graphic (PNG)-based stage delivery, configurable injection targets, camouflaged command-and-control (C2) URLs and a new Lua stealer plug-in along with auxiliary modules. ²⁹
Oct. 6, 2025	The release of Vidar version 2.0 was announced. ³⁰
Nov. 13, 2025	Europol announced the results of a joint operation by law enforcement agencies of several countries against the Rhadamanthys malware-as-a-service (MaaS), VenomRAT and the Elysium botnet environment. ³¹

Campaigns Trends

Node Package Manager Supply Chain Attack

In 2025, a series of npm supply chain compromises were identified, referred to collectively as [Shai-Hulud](#). These campaigns were characterized by their worm-like propagation and involved large-scale package trojanization coupled with credential theft.

Shai-Hulud

The initial campaign began Sept. 15, 2025, during which the popular package @ctrl/tinycolor was [compromised](#), along with more than 40 other npm packages. Within days, the scope of the attack expanded rapidly. By Sept. 18, 2025, the number of compromised packages exceeded 650. The attack is believed to have originated from a phishing campaign that specifically targeted the account of an npm package maintainer. A phishing email disguised as a security alert from npm tricked the developer into revealing their login credentials. Attackers then used this information to access the npm account and deploy a malicious payload that functions as a worm, initiating a multistage attack sequence.³²

Shai-Hulud: The Second Coming

A second major wave of attacks was detected Nov. 24, 2025, impacting popular packages from AsyncAPI, PostHog, Postman and Zapier, among others. Unlike the first wave, attackers infiltrated automated development pipelines, such as CI/CD systems, by exploiting compromised automation and publishing tokens. This allowed them to discreetly

modify workflows and release trojanized package versions across multiple organizations. At its peak, the breach affected about 26,000 GitHub repositories. The worm harvested credentials from major cloud platforms, including Amazon Web Services (AWS), Google Cloud Platform (GCP), Microsoft Azure and npm, employing stolen tokens to republish infected packages and deploy malicious GitHub Actions runners on affected systems.

This wave exhibited a destructive fallback behavior. If the malware failed to maintain authenticated access to both GitHub and npm during execution, it resorted to destructive actions, deleting and overwriting all user files within the home directory. This represents a significant escalation in impact compared to the first variant.³³

ClickFix Proliferation

In 2025, ClickFix became the malware proliferation method of choice and was leveraged for countless campaigns. The social-engineering delivery technique relies on user-driven execution and operates primarily at the traffic and conversion layer. Attackers use malvertising, search engine optimization (SEO) poisoning, compromised sites and fake landing pages to direct victims into a guided “fix” flow. In this flow, victims are instructed to copy, paste and run a command under the pretense of troubleshooting, verification or enabling content.

ClickFix campaigns typically follow a consistent pattern:

- **Traffic acquisition** — Victims are lured through malvertising, redirect chains, compromised websites, look-alike domains or “cracked software.”
- **Legitimacy framing** — Attackers present familiar scenarios, such as “browser check,” “Cloudflare verification,” “Zoom audio troubleshooting,” “Google Meet issue” or “Windows Update in progress.”
- **Guided execution** — The webpage provides step-by-step instructions that normalize unusual actions. Most commonly, this involves the user’s keyboard shortcuts — Win+R → Ctrl+V → Enter on Windows, or Terminal → paste → Enter on macOS. Frequently, the command is prestaged in the clipboard or displayed prominently to encourage blind copy and paste.
- **Payload retrieval and execution** — The pasted command usually downloads and executes a second-stage payload, which may include information stealers, loaders or RATs.

Intel 471 analysts observed dozens of ClickFix campaigns in 2025 and featured a few in Malware Campaign Reports, including:

- [Cracked software lures deliver information stealers to Windows, macOS via ClickFix attacks](#)³⁴
- [Actor *Burgundy leverages Cloudflare ClickFix technique to distribute multiple malware strains](#).³⁵

The popularity of ClickFix stems from its simplicity, scalability and effectiveness. As organizations enhance defenses against macro abuse, restrict attachments and improve email filtering, ClickFix bypasses these security measures by placing execution in the user's hands. Because the victim initiates execution, the activity can seem more legitimate in telemetry compared to a drive-by exploit. While many detections still occur, the attacker's objective is to ensure the user already has executed the malicious code.

Reflecting its widespread appeal, ClickFix phishing pages and kits now are prominently available in underground marketplaces. In 2025, Intel 471 analysts noted various threat actors advertising ClickFix-related offerings, including:

Handle	Type	Price	Report Title
*Blue	ClickFix	US \$2,000/ page	Actor *Blue offers malware for ClickFix social-engineering attacks, reveals operational details ³⁶
*Indigo	ClickFix	US \$1,600/ page	Actor *Indigo offers phishing project to deliver malware via ClickFix social-engineering technique ³⁷
*Beige	ClickFix	US \$1,500/ month	Actor *Beige offers phishing kits to harvest account credentials, deliver malware, leverages ClickFix social-engineering technique ³⁸
*Burgundy	ClickFix - "VulnCloudFlare"	US \$350/ kit	Actor *Burgundy offers VulnCloudFlare phishing kit, leverages ClickFix social-engineering technique ³⁹
*Turquoise	ClickFix - "Browser check"	US \$2,000/ month	Actor *Turquoise offers phishing pages exploiting ClickFix social-engineering technique for malware delivery ⁴⁰
*Violet	ClickFix - Google Meet, Zoom	US \$1,000/ kit	Actor *Violet offers to sell Google Meet, Zoom video-conferencing platform phishing toolkits, leverages ClickFix social-engineering technique ⁴¹
*Carmine	ClickFix	US \$500/ page	Actor *Carmine offers brute-forcing tools, malicious development service, phishing pages ⁴²

Some ClickFix pages are differentiated by highly specific and credible pretexts. One notable example is the "[Zoom audio troubleshooting](#)" lure the actor ***Violet** presented, who claimed the toolkit was employed in real-world attacks (see: Figure 20).⁴⁰ This claim was supported by a public post on the X aka Twitter social media network, which highlighted an instance of cryptocurrency wallets being compromised and funds drained following a



counterfeit Zoom call.⁴³ Additional details can be found in the report titled “[The State of Phishing Underground in 2025](#)”⁴⁴

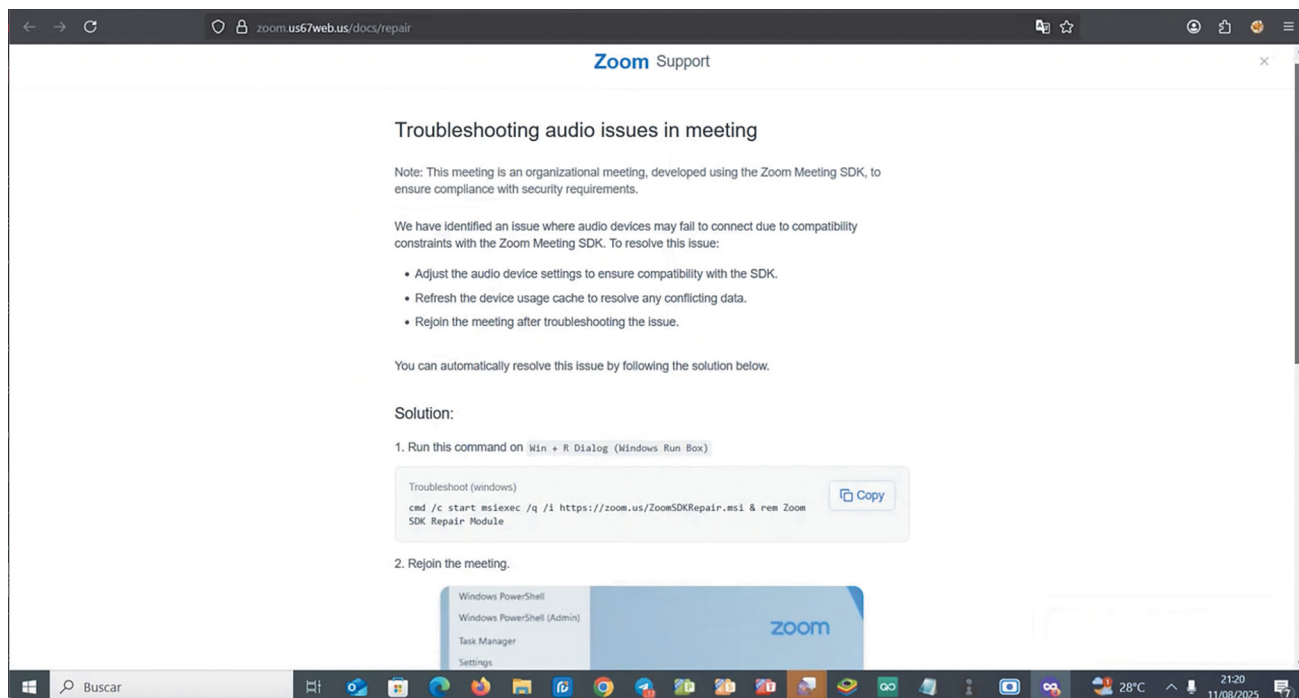
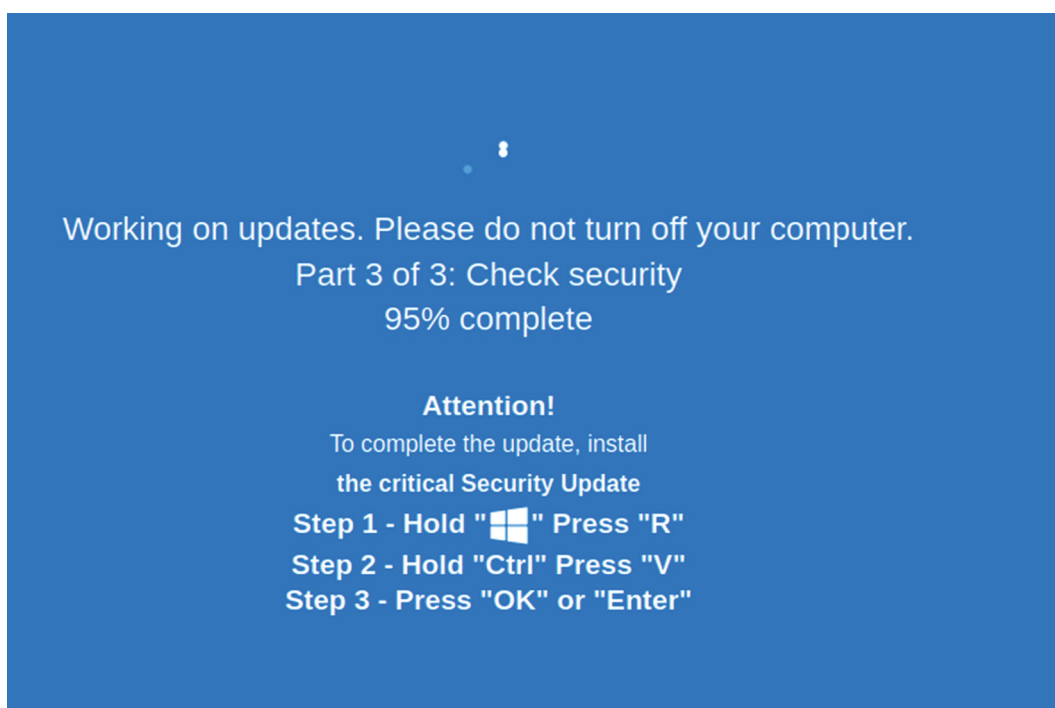


Figure 20: The image depicts a screenshot of the actor's video with a lure that tricks a victim into executing a malicious script on the system Sept. 15, 2025.

The most recent iteration observed by Intel 471 analysts features a Windows-themed ClickFix page that simulates a system process rather than a web prompt. This version deceives victims into believing Windows has initiated an update cycle by forcing the browser into full-screen mode and displaying a convincing Windows Update screen. At the culmination of the “update,” users are prompted to complete a final step, which involves using the familiar Win+R and Ctrl+V keyboard commands to paste and execute a malicious command (see: Figure 21).

In addition to Windows-themed ClickFix pages, threat actors increasingly are adopting macOS-specific ClickFix themes that embed clipboard-ready commands tailored for the macOS command line. This shift allows attackers to target macOS users who visit compromised or purpose-built sites hosting the ClickFix lure. Notably, in both of our Malware Campaign Reports involving ClickFix, threat actors targeted both Windows and macOS users, indicating an increasing push toward cross-platform delivery.^{34,35} This trend underscores the growing recognition of the value of the macOS user base, particularly as more organizations integrate Apple devices into their enterprise environments.



*Figure 21: The image depicts a screenshot of the Windows update ClickFix phishing page
Dec. 12, 2025.*

Outlook

Moving into 2026, we expect the volume of emulation-detected payloads to remain steady or decline slightly, reflecting adversaries' growing reliance on alternative delivery techniques — most notably ClickFix and malvertising. It is highly likely new ClickFix lure variants will continue to emerge, with threat actors refining the pretexts and presentation to appear as legitimate to users as possible. Given ClickFix's popularity and low operational friction, it is plausible we will see increased demand for traffic brokers aka traffers, as these campaigns benefit from scalable, prequalified user acquisition. In the information-stealer landscape, we anticipate a continued redistribution of market share, where Vidar and Stealc are well positioned to absorb demand created by the disruption of Lumma and Rhadamanthys. Additionally, several newcomers may enter the market, but whether they gain traction will depend on product quality, operator support, update cadence and the reliability of their delivery ecosystem. Finally, moving away from "typical" malware campaigns, we anticipate an increase in supply chain attacks characterized by worm-like automation, similar to Shai-Hulud. These attacks likely will target developer workflows and CI/CD pathways where execution can occur upstream — before standard endpoint controls or conventional security checks apply. As a result, dependency integrity and identity/credential hygiene will become even more critical.

Vulnerabilities

*This report incorporates data from multiple sources that included actor engagement observations, open source reporting, third-party intelligence and proprietary monitoring systems.*****

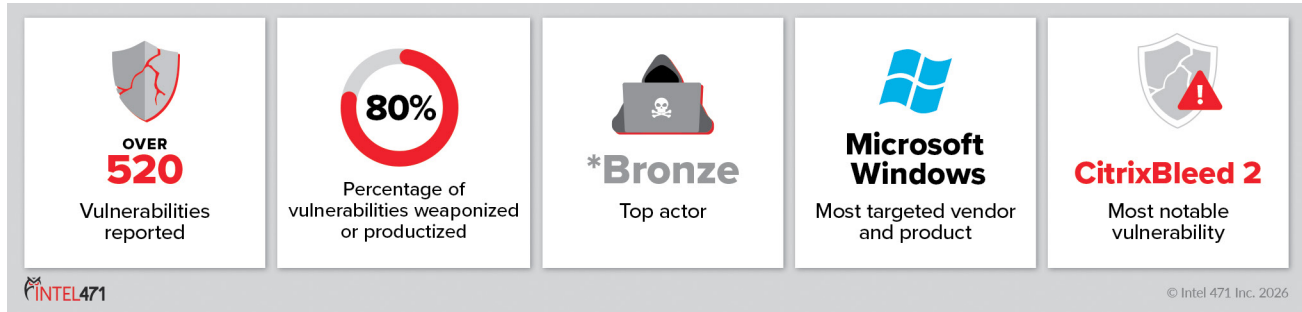


Figure 22: The image depicts top vulnerability statistics for 2025.

Summary

In 2025, the vulnerability threat landscape presented a significant challenge for defenders, with the total number of disclosed vulnerabilities surpassing 45,000. Our Vulnerability Intelligence team reported over 520 vulnerabilities, over 230 of which were observed in active exploitation campaigns and more than 80% of these either were weaponized or productized. The actors **zeroplayer** and ***Bronze** were assessed as the most notable exploit brokers, while CVE-2025-5777, CVE-2025-53770 and CVE-2025-55182 were vulnerabilities that required significant effort from operational teams.

Looking Ahead:

- AI likely will become a more prominent part of patch analysis and exploit development, enhancing attacks and exploitation through better and more improved agentic workflows, resulting in more automated attacks and reduced time-to-exploit.
- Rapid weaponization and reduced time-to-exploit will continue to be a factor in 2026. Attackers will continue to opportunistically exploit high attack surface initial access vulnerabilities, WordPress plug-in vulnerabilities and Internet-of-Things (IoT) vulnerabilities mainly for financial gain.

Vulnerability Statistics Overview

For a comprehensive understanding of GIR classification, please refer to our [General Intelligence Requirement \(GIR\) handbook](#).*****

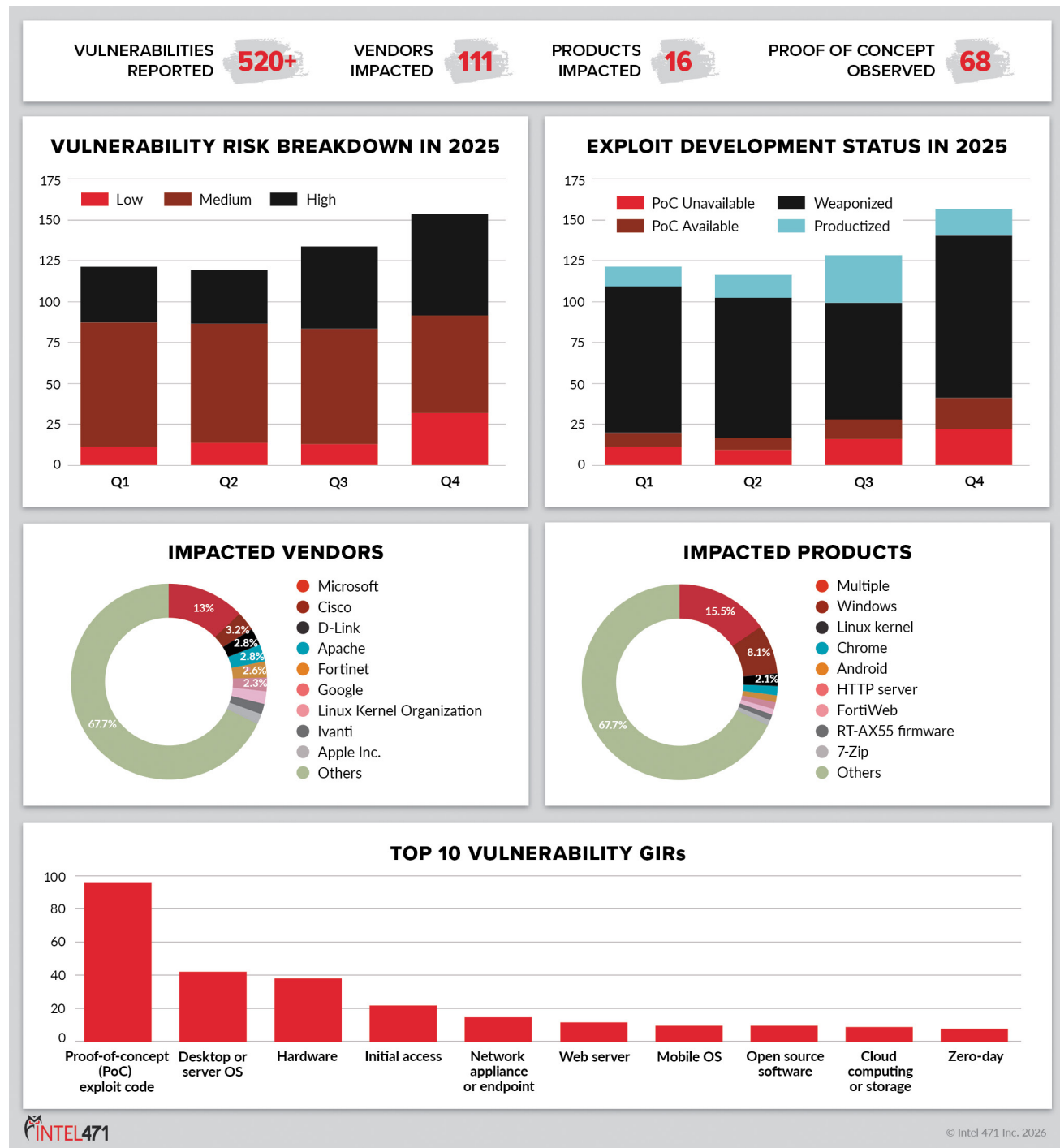


Figure 23: The image depicts the risk breakdown associated with the reported vulnerabilities, an overview of exploits available in the underground, the most impacted vendors and products and an overview of the top 10 vulnerability-related GIRs observed in 2025.

In 2025, the U.S. National Institute of Standards and Technology (NIST) National Vulnerability Database (NVD) recorded an increase of about 14% in the total number of disclosed vulnerabilities compared to 2024, rising from 39,970 to 45,425. The total number of vulnerability disclosures per quarter was steady, with numbers consistently ranging from about 11,000 to 12,000. The U.S. Cybersecurity and Infrastructure Security Agency (CISA) added 238 vulnerabilities to its Known Exploited Vulnerabilities (KEV) catalog, with 146 of these linked to CVE-2025 identifiers.

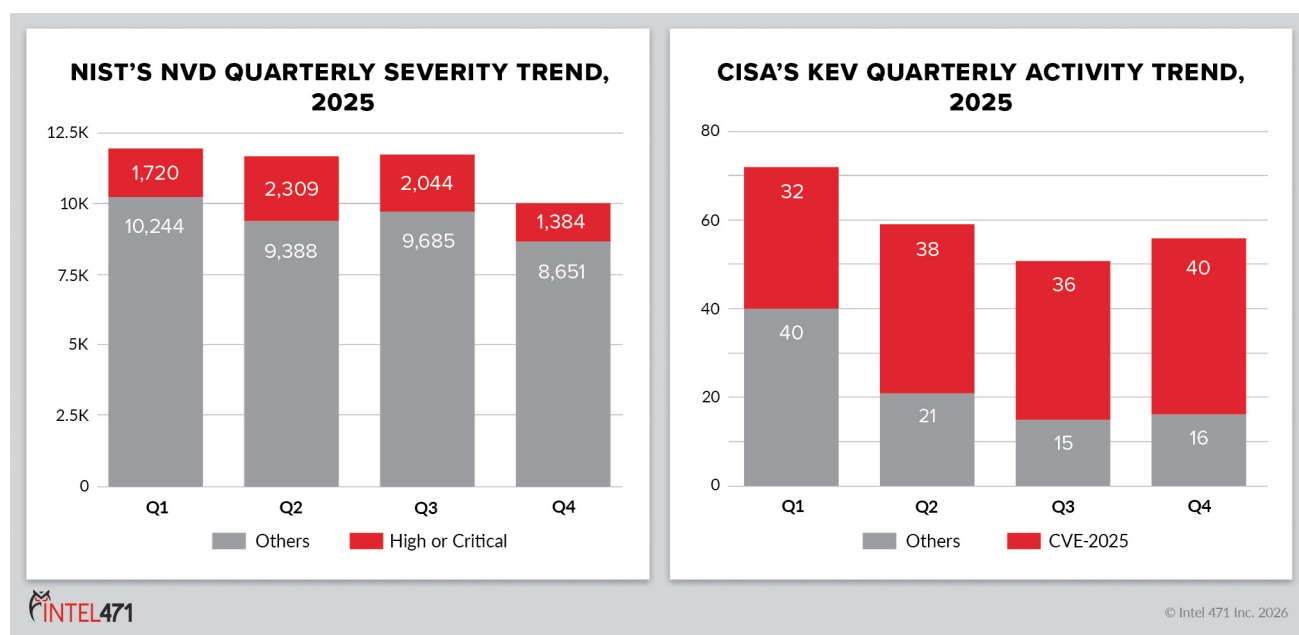


Figure 24: The image depicts a risk classification overview of all disclosed vulnerabilities in 2025 and the representation of the vulnerabilities disclosed in 2025 that were included in CISA's KEV catalog.

Prominent Exploit Brokers

This section profiles prominent threat actors and vulnerability brokers from 2025 who advertised vulnerabilities and exploits on underground forums. 2025 was a notably active year for sellers offering both n-day and zero-day vulnerabilities.

Top actor — **zeroplayer**

The actor **zeroplayer** is a Russian-speaking vulnerability and exploit broker who first appeared on the Exploit forum in July 2025. The actor primarily advertised

2025 WAS A
NOTABLY ACTIVE
YEAR FOR SELLERS
 OFFERING
 BOTH N-DAY
 AND ZERO-DAY
 VULNERABILITIES

zero-day vulnerabilities for widely deployed enterprise-grade software products and OSs. In 2025, **zeroplayer** offered exploits for alleged zero-day vulnerabilities impacting Cisco, pfSense, Microsoft Word, Windows, WinRAR, WinZip and multiple Linux distributions. The actor also offered an endpoint detection and response (EDR) evasion tool that leveraged the bring-your-own-vulnerable-driver (BYOVD) technique.

Top actor — ***Bronze**

The actor ***Bronze** is a well-known exploit and vulnerability broker who first appeared on the Exploit and XSS forums in 2018. The actor has a history of offering exploits for alleged zero-day vulnerabilities impacting prominent enterprise-grade software and hardware products including Microsoft Windows, the Webuzo web server management platform, Cisco routers and Juniper SRX firewalls. In 2025, ***Bronze** most notably offered exploits for alleged zero-day vulnerabilities impacting Fortinet, Kerio Connect, ManageEngine, Windows and several Linux distributions.

Notable Vulnerabilities

This section highlights the most significant vulnerabilities disclosed in 2025, selected for their impact on organizations and real-world exploitation. As in previous years, threat actors in 2025 rapidly weaponized critical disclosures, accelerating the window between public awareness and active exploitation.

CVE-2025-5777 aka CitrixBleed 2

CVE-2025-5777 | Out-of-bounds read | Citrix NetScaler

CVSSv3: 9.3

Risk: HIGH

Impact: Account takeover

Associated actor(s): N/A

Associated malware: N/A

✓ CISA KEV

✗ Code available

✓ Weaponized

✗ Productized

✓ In the wild

✓ PoC

✓ Sought in the underground

✗ Exploit advertised

INTEL471

© Intel 471 Inc. 2026

On June 17, 2025, Citrix disclosed [CVE-2025-5777](#), a critical out-of-bounds vulnerability in the NetScaler application delivery controller, and on June 26, 2025, ReliaQuest reported CVE-2025-5777 was being exploited in the wild. Its telemetry revealed session hijacking

© Intel 471 Inc. All rights reserved.



patterns, reuse of stolen tokens and immediate post-authentication reconnaissance – all consistent with prior CVE-2023-4966 aka CitrixBleed vulnerability exploitation. This resemblance led to CVE-2025-5777 gaining the informal moniker CitrixBleed 2 within the cybersecurity community. Exploitation of both vulnerabilities leads to memory leak and the exposure of sensitive session data. On July 4, 2025, a publicly available exploit was released for CVE-2025-5777, significantly raising the risk of exploitation for vulnerable organizations. Recognizing its immediate threat, CISA added CVE-2025-5777 to its KEV catalog July 10, 2025, and urged federal agencies and the private sector to prioritize patching.⁴⁵

CVE-2025-53770 aka ToolShell

CVE-2025-53770 | Deserialization of untrusted data | Microsoft SharePoint

CVSSv3: **9.8**

Risk: **HIGH**

Impact: **Remote code execution**

Associated actor(s): **Linen Typhoon, Violet Typhoon**

Associated malware: **Warlock ransomware**

☒ **CISA KEV**

☒ **Code available**

☒ **Weaponized**

☐ **Productized**

☒ **In the wild**

☒ **PoC**

☒ **Sought in the underground**

☐ **Exploit advertised**

On July 19, 2025, Microsoft released patches for the newly disclosed [CVE-2025-53770](#), a critical unauthenticated remote code execution (RCE) vulnerability caused by unsafe deserialization in on-premises SharePoint Server software. Microsoft also announced CVE-2025-53771 – a path traversal spoofing bug reported by an independent researcher. CVE-2025-53770 was widely exploited in the wild and multiple threat actors shared working exploits for the vulnerability on prominent underground forums, prompting considerable interest from financially motivated cybercriminals. Additionally, several high-profile actors actively sought functional exploits for CVE-2025-53770, demonstrating the exploit’s potential value and broad appeal within the cybercrime ecosystem.⁴⁶

CVE-2025-55182 aka React2Shell

CVE-2025-55182 | Deserialization of untrusted data | React

CVSSv3: **10.0**

Risk: **HIGH**

Impact: **Remote code exection**

Associated actor(s): **Earth Lamia, Jackpot Panda**

Associated malware: **N/A**



CISA KEY



Weaponized



In the wild



Sought in the underground



Code available



Productized



PoC



Exploit advertised



© Intel 471 Inc. 2026

On Dec. 3, 2025, React released fixes for a deserialization of untrusted data vulnerability tracked as [CVE-2025-55182](#) aka React2Shell impacting the React JavaScript library's Server Component. The vulnerability also affected the React frameworks and bundlers such as the packages "nextjs," "react-router," "waku" and "rwsdk." React2Shell quickly gathered attention from security researchers and threat actors due to its maximum Common Vulnerability Scoring System (CVSSv3.1) score of 10.0, its potential for RCE and a high potential attack surface due to the popularity and widespread usage of React on a wide range of web applications. On Dec. 4, 2025, shortly after the vulnerability's initial disclosure, an exploit became available on the GitHub software development platform. The same day, AWS reported China-nexus threat groups rapidly were exploiting the vulnerability in opportunistic attacks. Shortly after, security researchers at CISA claimed the vulnerability was actively exploited in the wild and security researchers at GreyNoise reported they observed a wide range of attacks targeting the vulnerability. Open sources suggested attacker post-compromise behavior included cryptocurrency miner deployment, cloud credential harvesting, deploying web shells, deploying backdoors and attempts to install Cobalt Strike.⁴⁷

Relevant Vulnerability Exploitation Campaigns

Over the last 12 months, we observed five key vulnerabilities that were actively exploited to obtain initial access to vulnerable organizations. These vulnerabilities were abused by a range of threat actors that included state-sponsored clusters, underground actors, and extortion and ransomware operators.

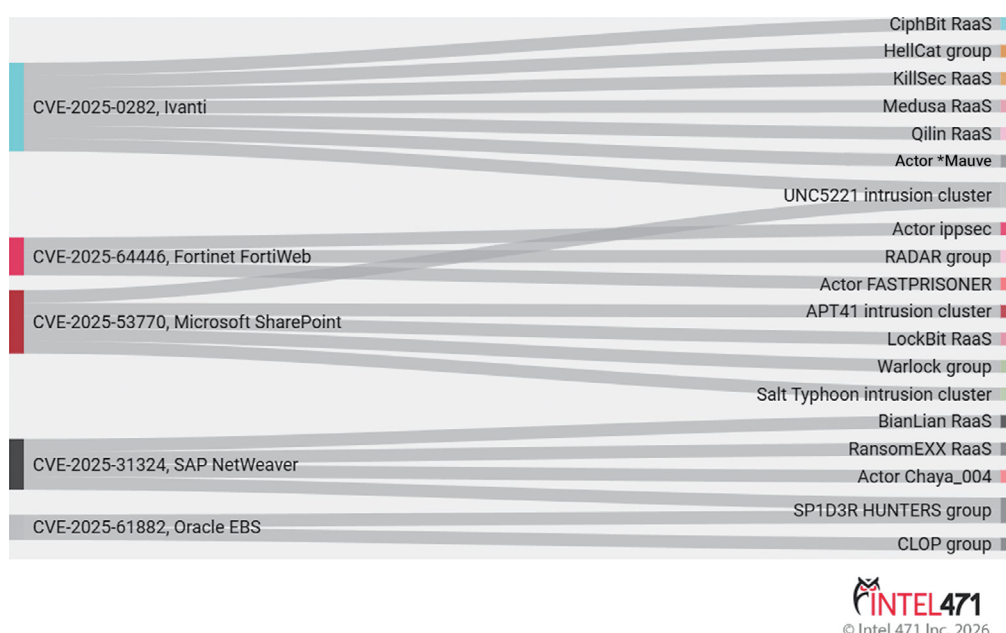


Figure 25: The image depicts a Sankey diagram illustrating the correlation between the relevant vulnerabilities and adversary exploitation campaigns observed in 2025.

Outlook

Moving into 2026, the volume of newly discovered vulnerabilities is expected to remain high, driven by expanding software supply chains, increased scrutiny of widely deployed open source components and the growing complexity of enterprise-grade platforms. Threat actors across the spectrum — from financially motivated groups to state-aligned adversaries — are expected to focus on high-impact initial access vulnerabilities affecting ubiquitous technologies.

It is anticipated that AI will play an increasingly transformative role with adversaries expected to leverage AI-enabled capabilities to enhance patch analysis of newly disclosed vulnerabilities to identify flaws and enable quicker exploit generation. These advancements also will increase the scalability of exploit production and enable less technically sophisticated actors. AI also is poised to introduce new risks in 2026, particularly through the rise of “vibe coding” practices — AI-generated code produced with minimal human oversight or structured engineering discipline. As organizations increasingly rely on AI to accelerate development cycles, the absence of rigorous quality assurance, secure design principles and formal testing processes may lead to the widespread introduction of insecure code into production environments.

With these developments alongside continued offers of zero-day exploits in underground markets, organizations should anticipate a faster, more automated and more opportunistic exploitation landscape throughout 2026.

Hacktivism

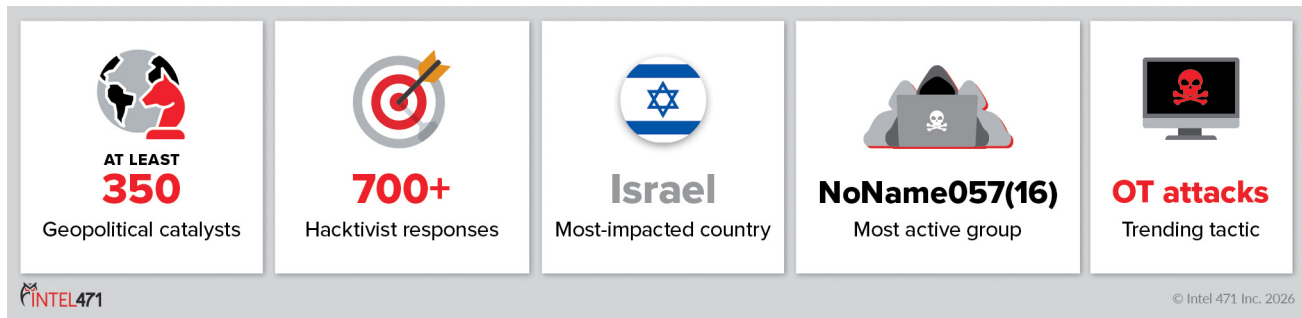


Figure 26: The image depicts top hacktivism statistics for 2025.

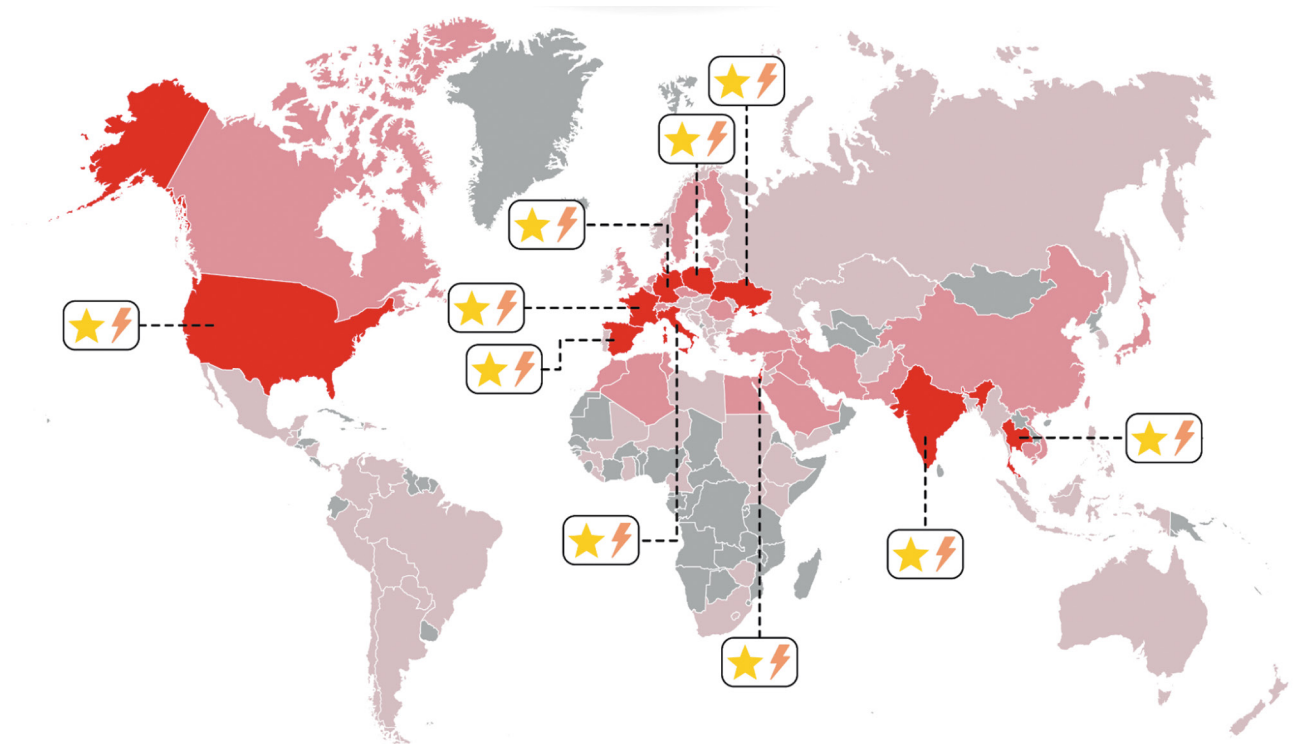
Summary

Hacktivism in 2025 was similar to that of 2024, with the two focal points being the conflicts between Israel and Hamas and Russia and Ukraine. The majority of activity pertained to developing events within the countries and the geopolitical maneuvering of countries looking to influence the outcomes of the conflicts. The diversity of groups began to wane, with only the most ardent actors consistently active. The longevity of these groups likely is driven by their state links and less a form of protest. Beyond these conflicts, regional flare-ups precipitated corresponding flare-ups in the underground. Regional skirmishes also precipitated a mirrored response among hacktivist groups, including the Cambodia-Thailand border dispute, terrorist activity likely related to India-Pakistan tensions and escalating civil unrest in Sudan. Finally, while DDoS attacks remained the weapon of choice for most groups, a growing number sought to target operational technology (OT) with the goal of undermining critical national infrastructure.

Looking Ahead:

- Pro-Russian hacktivism will persist. However, the majority of attacks likely will be carried out by a small number of devout groups, such as **NoName057(16)**, who remain active while others disappear as a result of desensitization and burnout from the protracted nature of the conflict.
- Hacktivists will continue to increasingly target OT systems. However, this likely will not culminate in the form of complex exploitation, but rather opportunistic attacks on poorly secured targets.

Global Impact of Hacktivism



Country	Claims of attack	Catalyst events ⚡	Operations of interest ★
Israel	1558	29	32
Ukraine	1369	34	9
France	702	8	19
India	625	6	3
Germany	614	8	9
Italy	594	8	5
USA	547	16	13
Poland	467	4	2
Spain	465	3	10
Thailand	449	1	10

Figure 27: The image depicts the density of hacktivism operations observed and the locations of highlighted operations and catalytic events in 2025.

Geopolitical Events Prompting Hacktivism Response

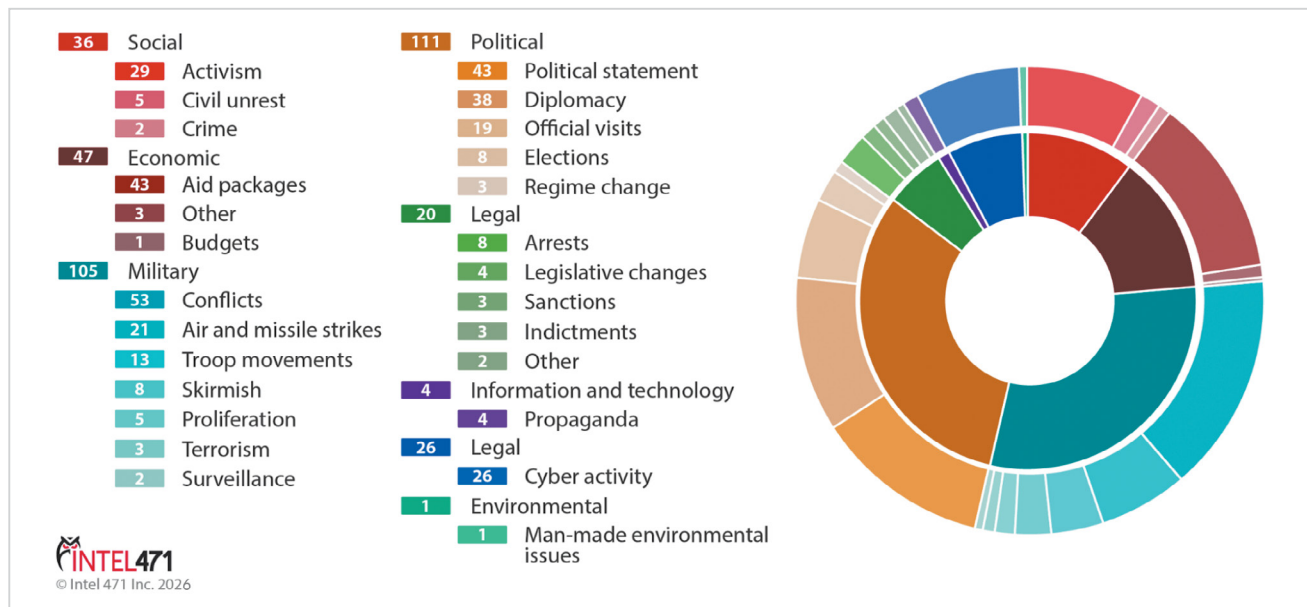


Figure 28: The image depicts the types of events that precipitated reactions from tracked hacktivist groups in 2025.

From Jan. 1, 2025, to Dec. 15, 2025, we identified 350 geopolitical events that likely corresponded to hacktivist claims observed in the underground – the details of which can be found in our monthly hacktivism highlights reports. The breakdown of these events provides an indication of the types of activity more likely to precipitate a response from hacktivist groups. Further analysis allows us to group some of the events into broader thematic drivers.

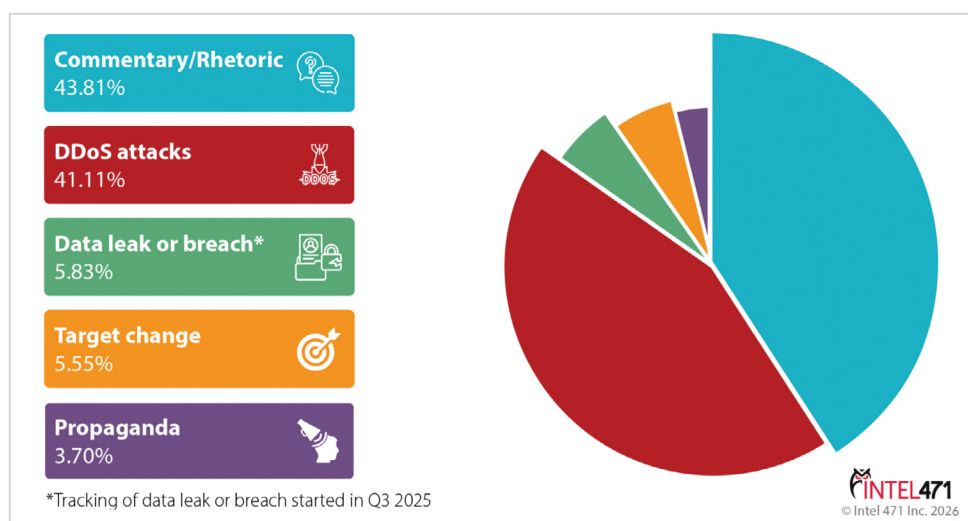


Figure 29: The image depicts the type of activity associated with responses to events from hacktivist groups in 2025.

Catalysts

Support to Ukraine

As we approach the fourth anniversary of Russia's invasion of Ukraine, the conflict continues to provoke a significant hacktivism response from pro-Russian groups seeking to impact nations seen to aid Ukraine economically, humanitarially and/or militarily. This catalyst was consistent throughout 2025 and the groups who seized upon it included **CLOBELSECTEAM**, **Dark Storm Team**, **KillNet**, **Mr Hamza**, **NoName057(16)**, **Overflame**, **Red wolf cyber**, **ServerKillers**, **TwoNet** and **Z-Pentest Alliance**.

The most active of these groups was **NoName057(16)**. The group routinely announced operations against mainly European entities for their various methods and/or announcements of support to Ukraine. The most significant operation as a result of support to Ukraine during each month of 2025 can be seen in Figure 29 below.

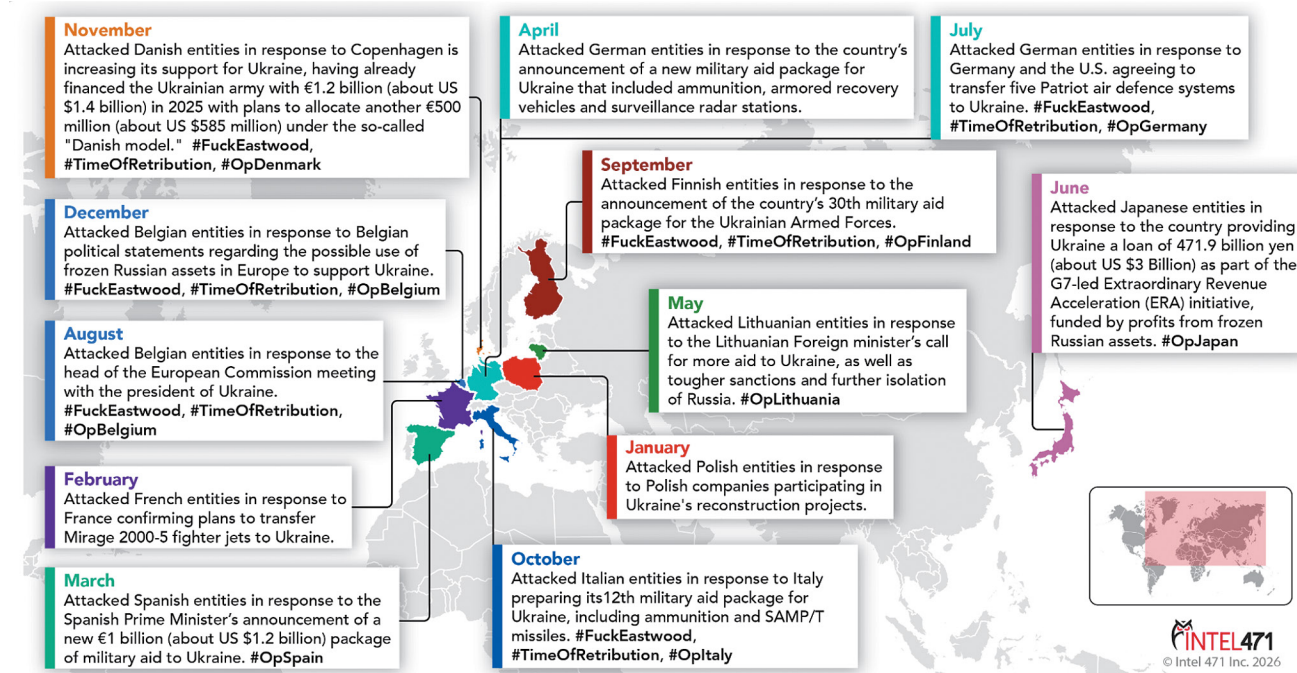


Figure 29: The image depicts a map showing the most significant operations undertaken by **NoName057(16)** each month across 2025, as a result of support to Ukraine.

Operation Eastwood

As a result of the barrage of attacks coming from pro-Russian hacktivist groups this year, the **NoName057(16)** group and its infrastructure was the target of a [joint international operation](#) dubbed Operation Eastwood coordinated by Europol and the European Union Agency for Criminal Justice Cooperation (Eurojust). From July 14, 2025, to July 17, 2025,

authorities from several countries simultaneously took action against individuals and infrastructure associated with the group.⁴⁸ However, the group was minimally impacted as we observed only about a week of no activity from its DDoSia infrastructure.

Moreover, upon reestablishing its network, the **NoName057(16)** group and its allies — such as **CLOBELSECTEAM**, **Dark Storm Team**, **HeziRash**, **Mr Hamza**, **Red wolf cyber**, **Server-Killers** and **Z-ALLIANCE** — carried out a [bombardment of attacks in retaliation](#).⁴⁹

⁵⁰ In late July 2025, Germany — which specifically was responsible for most of Operation Eastwood's arrest warrants and some home searches — bore the majority of the initial backlash. However, focus later switched to include Spain, Belgium, the Czech Republic and then a host of other European countries. By September, the **NoName057(16)** group reverted back to traditional targeting patterns, yet the #FuckEastwood and #TimeOfRetribution tags [still endure](#) at the time of this report.⁵¹

NoName057(16)
GROUP WAS
MINIMALLY
IMPACTED BY
OPERATION
EASTWOOD.

Violence and Humanitarian Crisis in Gaza

Another keystone catalyst for the year was the ongoing violence and humanitarian crisis in the Gaza Strip brought on by the continued conflict between Israel and Hamas. The year started off with a “first stage” ceasefire agreement between Israel and Hamas, providing some initial respite. However, while groups such as **Alixsec** announced a short break from activity at the end of January 2025, the **LulzSec Black** group said it would not stop its attacks until the Palestinian territories, Egypt and Jordan were liberated and claimed to launch [“cyber jihadist” operations](#) against Israeli entities.⁵²

By March 2025, the humanitarian situation rapidly declined when Israel launched surprise airstrikes on Gaza, citing Hamas' refusal to accept an extension of the ceasefire agreement. At this point, increased fighting and violence resumed. In May, the region saw a surge in mass casualty attacks, and by August, the Integrated Food Security Phase Classification (IPC) Famine Review Committee (FRC) reported the most severe deterioration since the IPC began analyzing acute food insecurity and acute malnutrition in the Gaza Strip — marking the first time a famine officially has been confirmed in the Middle East region.

Several hacktivist groups took to the underground to express their concern about the situation and claimed responsibility for attacks against Israel. We also observed attacks impacting Egypt-based resources over concerns the country's border blockade was exacerbating starvation in Gaza. The **RuskiNet** group was observed [targeting and calling](#)



[on others to target Egypt](#) alongside the #GazaStarving, #OpEgypt and #OpenTheGates tags.⁵³ We also saw [several comments](#) in Telegram channels associated with the **Cyber Jihad Movement**, **Shadow Cyber Unit** and **Yemen Cyber Force** groups [criticizing Egypt's lack of involvement](#).^{54,55}

As we moved into the final quarter of 2025, a new ceasefire agreement came into effect Oct. 10, 2025. We subsequently observed attacks against Israel carried out on a much smaller scale. The suspected Iranian nation-state-controlled **Cyber Toufan** group initially claimed it would [“respect the ceasefire”](#) and halt activity but appeared to resume activity against Israel in late October.⁵⁶ Over the final few months of 2025, attacks against Israeli entities remained, albeit at much lower levels than pre-ceasefire. Moreover, while the October ceasefire remains in effect at the time of this report, it repeatedly has been breached by both sides with various attacks, targeted killings and continued displacement.

Other Regional Conflicts

Border Dispute Between Thailand and Cambodia

In May 2025, a border clash between Cambodian and Thai forces resulted in the death of a Cambodian soldier. Tensions increased in July when deadly clashes once again broke out between troops from both sides — killing at least 12 people and injuring many others. As a result, several hacktivist actors and groups — including the pro-Cambodian hacktivist group [BL4CK CYB3R](#) and the [DarkStorm, K0LzSec, NNDSEC and NXBBSEC groups](#) — responded by issuing warnings and launching cyberattacks targeting Thailand-based government ministries, media platforms, private sector organizations and university websites.^{57,58} In December, another skirmish along the border wounded two Thai soldiers, which led Thailand to launch airstrikes. The **BL4CK CYB3R** group subsequently returned with attacks on Thailand, while the **Ghilan Legion** group targeted Cambodia.

Violence in Sudan

In late October 2025, the capital of North Darfur, el-Fasher, fell to the paramilitary Rapid Support Forces (RSF), with reports of mass executions and crimes against humanity. This ignited a hacktivism response. The **Keymous** group [claimed to target the RSF's official website](#) with a DDoS attack and [several other groups](#) — including **Keymous**, **Ghilan Legion** and **SYLHET GANG-SG** — targeted United Arab Emirates (UAE)-based entities for the country's alleged support of the RSF.^{59,60}

Notable Tactics, Techniques and Procedures

Attacks on Operational Technology Systems

The targeting of OT systems, often aimed at critical national infrastructure (CNI), remained a trend this year. Several groups were observed targeting industrial control systems (ICSs), including supervisory control and data acquisition (SCADA) and human-machine interface (HMI) systems. One of the most active pro-Russian hackers synonymous with these attacks was the **Z-Pentest Alliance group**. The group's attacks included an instance against the HMI system of [an Italy-based water treatment company](#), the HMI environment of a [Poland-based steel construction company](#) and alleged unauthorized access to a [hydroelectric power station](#).^{61,62,63} Another group conducting attacks on OT systems in 2025 was **Dark Engine** aka **Infrastructure Destruction Squad**, **Отряд Разрушения Инфраструктуры**, who allegedly operated in line with pro-Russian and pro-Chinese interests. The group made unsubstantiated claims to have used VoltRuptor malware to conduct destructive attacks within victim ICS environments.

We also observed several other groups, such as **IT Army of Russia**, **NoName057(16)**, **OverFlame**, **PalachPro**, **SECTOR16** and **TwoNet**, that historically focused on DDoS attacks, expand their activity to target ICS and SCADA environments. The **NoName057(16)** group claimed to gain unauthorized access to the HMI system of [a French hydropower plant](#) and the **IT Army of Russia** group claimed it carried out a series of coordinated cyberattacks impacting [five Ukrainian power plants](#).^{64,65}

Outlook

The situation in Gaza and Russia's war in Ukraine persisted as the two dominant catalysts for hacktivism activity in 2025 and likely will remain as such as we enter 2026. The observed cool down in attacks against Israel toward the end of the year is noteworthy and likely was the result of the October ceasefire. Nevertheless, the situation remains precarious and any significant breakdown or violation of the ceasefire almost certainly will reignite hacktivism interest in the region and likely will be focused toward Israel and/or its supporters.

Hacktivism pertaining to the protracted war between Russia and Ukraine remained a focal point, albeit from a few dedicated groups — most of which are assessed to be either state run or influenced. The length of the conflict and vying interests almost certainly led to a waning interest from the non-Russian community. Nevertheless, our assessment remains that as Western efforts to aid Ukraine — whether financial, military and/or humanitarian — endure, so will attacks from devout pro-Russian hackers seeking to augment Russian activity on the battlefield with attempts of eroding the political will of their enemies' allies.



Lastly, in relation to hacktivist TTPs, the supremacy of DDoS attacks likely will remain but possibly on a smaller scale compared to previous years. Additionally, building on momentum from 2025, we expect hacktivists likely will intensify their targeting of CNI and embedded OT systems to maximize operational impact. However, we assess the majority of hacktivist collectives likely lack the technical sophistication to carry out complex OT system exploitation or leverage zero-day vulnerabilities and likely will persist with opportunistic attacks on poorly secured targets.

Predictions for 2026

Themes that likely are to dominate the underground and cybersecurity landscape in 2026 include:

Ransom payments likely will wane forcing extortion groups to alter pressure tactics — Earlier in the year, analysis of the **BlackBasta** leaks revealed the group's operators were frustrated with the number of compromised organizations paying ransoms. This reluctance to pay likely is indicative of the wider threat environment and almost certainly contributed to the need for extortion groups to appoint data analytic functions to discover ways in which to increase pressure on entities. With the U.K. and Australia already introducing legislation to deter ransom payment — and possibly others to come — the trend likely will be exacerbated, forcing threat groups to find new ways to compel victims or look to sell.

Passive malware distribution methods will continue to outpace active methods — This year we observed a steep decline in artifacts pertaining to PPI services continuing a trend that began late 2023. The downturn is due in part to the multiple law enforcement operations that disrupted many of the leading PPI malware but also as result of a broader evolution to the ecosystem in general. In 2025, passive distribution methods — particularly ClickFix and malicious advertising (malvertizing) — became hugely popular due to the minimal resources required to leverage them and the lack of dependency on third parties whose compromise could halt operations or expose the user. This newfound popularity almost certainly will mean these passive methods become more refined as threat actors vie for supremacy. We equally expect vendors will seek to introduce new defenses to combat their rise.

Supply-chain flaws will continue to be sought by skilled actors — Capable and well-resourced threat actors and data-extortion groups are assessed to prioritize zero-day supply-chain vulnerabilities because they offer a high-confidence path to outsized monetization. A single previously unknown flaw in a widely deployed SaaS, MSP, or MFT platform can enable rapid one-to-many compromise, exploit trusted relationships and drive broad downstream impact before defenders can patch, detect or attribute activity —

maximizing both the number of potential victims and the leverage available for extortion. Given the demand, zero-day brokers and access providers are likely to monetize exclusivity by brokering “fresh” exploit paths and pre-positioned upstream access. This will sustain a market where scarcity and speed-to-exploit command premium pricing and increase the operational tempo of top-tier groups. In parallel, we assess dependency and package-ecosystem compromises will increase in frequency and sophistication — as adversaries target CI/CD automation, maintainer identities and trusted update channels to distribute malicious code at scale.

AI is unlikely to emerge as the central threat in cybersecurity but will continue to serve as a force multiplier for threat actors — AI is expected to be leveraged primarily as an efficiency enhancer rather than the core driver of malicious operations. Its most sustained impact will likely be in the realm of social engineering — enabling more sophisticated phishing and BEC lures, more natural-sounding vishing scripts, and rapid production of fluent, multilingual, context-aware content in text, voice, image and video formats. Meanwhile, the concept of “AI malware” is projected to remain more marketing than operational reality. There is little incentive for profit-driven adversaries to adopt malware dependent on LLMs due to increased cost, complexity, and reliance on external infrastructure, especially when proven loaders or stealers remain effective. Rather than widespread adoption of AI-dependent malware, we predict targeted escalation in areas where AI demonstrably increases the return on investment — such as deepfake-driven impersonation, AI-generated voice fraud targeting high-value individuals, and amplified synthetic media in influence operations around elections, geopolitical flashpoints and divisive social debates. In these scenarios, scale and plausibility often outweigh perfection, and AI is poised to play a significant supporting role.

Hacktivism will be more an extension of state power, less an act of ideological protest — Since the onset of the Russia-Ukraine war the hacktivism landscape underwent a slow but distinct change. Initially, groups involved with the hostilities were predominantly low-skill hobbyists drawn to hacktivism due to ideology, nationalism and self-interest. These groups came and went in equal measure. As the conflict wore on, the number of groups narrowed, leaving only the most dedicated and capable. Recent reporting revealed many of these groups on both sides were associated with their respective states, providing a likely driver for their longevity. Likewise, when analyzing hacktivism associated with the Israel-Palestine conflict many of the most active groups reportedly possess links to Iranian or Israeli intelligence services. In 2026, as long as conflicts involving cyber capable nations endure, the hacktivism domain will be one increasingly dominated by nation-state influenced or controlled actors.

Crackdown on ransom payments likely will result in increased payment card fraud — Payment card fraud likely will continue to increase, specifically due to the prevalence of the compromised data market and availability of card-not-present (CNP) data. AI likely will have an impact on this, predominantly in phishing operations as well as know-your-customer (KYC) bypass techniques. Additionally, as governments continue to crack down on extortion and ransomware operations — either via law enforcement action or regulation regarding payments of extortion demands — more actors likely will turn back to less conspicuous methods of fraud for monetary gain while incurring less risk. Payment card fraud is a tried and true method with an established ecosystem dedicated to it in the underground, so it is likely many actors looking for alternative fraud schemes will find this type of activity attractive.

General Intelligence Requirements

Intel 471's General Intelligence Requirements (GIRs) are our standardized taxonomy that separates cyber underground activity into categories of threat type, technique, sector or theme. These enable customers to filter and prioritize reporting quickly and consistently, focusing on what's most relevant to their unique environment. The GIRs tagged in the above report have been listed below:

- 1.1.1 Ransomware malware
- 1.1.2 Mobile malware
- 1.1.3 Remote access trojan (RAT) malware
- 1.1.4 Banking trojan malware
- 1.1.5 Information-stealer malware
- 1.1.6 Loader malware
- 1.1.7 Botnet malware
- 1.2.1 Multifunctional malware-as-a-service (MaaS)
- 1.2.2 Ransomware-as-a-service (RaaS)
- 1.3.8 Malware spamming
 - 1.3.11.8 Artificial intelligence (AI)

2.1 Vulnerabilities

- 2.1.1 Operating system (OS) vulnerabilities
- 2.1.2 Software and web application vulnerabilities
- 2.1.4 Server platform vulnerabilities

2.1.4.5 Application server vulnerabilities

2.1.5 Network appliance or endpoint vulnerabilities

2.2 Exploit development

2.2.1 Proof-of-concept (PoC) exploit code

2.2.2 Exploited in wild

2.2.3 Exploit advertised

3.3 Dedicated criminal infrastructure

4.3.3 Account brute forcing

4.3.4 Subscriber identity module (SIM) swapping

4.1.2.1 Cryptocurrency exchange fraud

4.2.2 Compromised credentials

4.2.5 Compromised network or system access

4.4.1 Phishing

4.7.1 Wholesale access

4.7.2 Specified access

5.2.12.2 Denial of service (DoS) technique

5.5.4 Blackmail and extortion

5.5.5 Supply chain attack tactic

5.5.6 Hacktivism

6.1 All sectors and industries

6.2 All geographic regions

Notes and Disclaimers

** Ransomware groups do not typically broadcast ransomware breaches when the victim pays the desired ransom. Therefore, it is important to highlight that our analysis is based on events specifically observed and recorded by Intel 471. Ransomware strains are listed according to their most recent nomenclature at the time of this report. Additionally, we included raw observables as part of the analysis of emerging variants and common tactics, techniques and procedures (TTPs). Since Operation Cronos – the international law enforcement disruption operation against the LockBit RaaS – the LockBit group continued to add victims to its data leak blog. These claims were contested in subsequent Op Cronos statements, which claimed many of the victims were fabricated or falsified. It is not possible to discern which were accurate, therefore, we included all claims in our statistics.*

*** The reporting metrics for this section were sourced from Intel 471 Breach Alerts, Information Reports and auction offers made on the Exploit forum and are not representative of all access possibly offered across the underground. It is important to highlight that our analysis is based on events specifically observed and recorded by Intel 471. Some access offers captured in our data points remain unverified at the time of this report. Additionally, we included raw observables as part of the analysis of emerging threats and common TTPs.*

**** The malware landscape is an ever-changing environment where metrics vary greatly based on several factors including the frequency of execution of our emulation tools and the malware family coverage for the detection of those payloads collected through emulation. We believe our monitoring tools offer a more accurate depiction of the real underground use of malware, instead of having data polluted from submissions from malware sharing platforms.*

***** This report incorporates data from multiple sources that included actor engagement observations, open source reporting, third-party intelligence and proprietary monitoring systems. Because these sources offer varying levels of visibility and evidence, attribution for some vulnerability exploitation campaigns may remain unverified or incomplete. Any attribution provided reflects the best assessment based on currently available information and should be considered provisional, subject to change as additional intelligence becomes available.*

****** The “initial access vulnerability” GIR was introduced during the Sept. 15, 2025 GIR handbook update and as such the data only represents the period commencing.*

Sources

1. Verity471 Whitepaper. "Precision deception: Rise of artificial intelligence-powered social engineering." 01 Aug 2025
2. Verity471 Information Report. "Actor offers to lease InboxPrime AI Gmail-based, artificial intelligence-powered spamming tool." 05 Nov 2025
3. Recorded Future. "AI Malware: Hype vs. Reality." 01 Dec 2025
4. Verity471 Intelligence Bulletin. "International law enforcement operation seizes Cracked, Nulled underground forums." 30 Jan 2025
5. Verity471 Spot Report. 14 Apr 2025
6. Verity471 Intelligence Bulletin. "Unidentified instability impacts BreachForums underground forum." 14 Aug 2025
7. Verity471 Spot Report. 10 Oct 2025
8. Verity471 Intelligence Bulletin "XSS forum administrator allegedly arrested, infrastructure disrupted." 04 Sept 2025
9. Verity471 Information Report. "Actor updates Qilin ransomware-as-a-service affiliate program." 23 May 2025
10. Verity471 Forum Post: Qilin RaaS. 4 May 2025
11. Verity471 Actor Profile. "Haise." 29 Jul 2025
12. Verity471 Information Report. "Actor offers data audit, analysis service for extortion, ransomware groups." 17 Apr 2025
13. Verity471 Information Report. "Actor offers to provide data audit, negotiation service for extortion, ransomware operators, claims to cooperate with RansomHub group members." 10 Jun 2025
14. Thomson Geer. "Australia's mandatory ransomware payment reporting rules: What your organisation needs to know." 16 Oct 2025
15. Lexology. "New Ransomware Legislation on the Horizon." 13 Oct 2025
16. Verity471 Intelligence Bulletin. "Extortion ecosystem update: Leaks, breaches, takeovers." 30 May 2025
17. Verity471 Intelligence Bulletin. "Possible mass exploitation of Cleo vulnerabilities by CLOP ransomware, data-extortion group." 24 Feb 2025
18. Verity471 Intelligence Bulletin. "Salesloft breach potentially impacts hundreds of organizations." 10 Sep 2025
19. Verity471 Data Leak Post. 14 Sept 2025

20. The Hacker News. "Qilin Ransomware Turns South Korean MSP Breach Into 28-Victim 'Korean Leaks' Data Heist." 26 Nov 2025
21. Verity471 Actor Profile. 28 Oct 2025
22. Verity471 Actor Profile. 28 Jan 2025
23. Verity471 Intelligence Bulletin. "Access brokers abuse living-off-the-land binaries to enhance offers, produce proof of compromises." 01 Oct 2025
24. Verity471 Intelligence Bulletin. "Malware metrics reviewed – January 2025." 05 Feb 2025
25. Verity471 Intelligence Bulletin. "Malware metrics reviewed – February 2025." 05 Mar 2025
26. Verity471 Intelligence Bulletin. "Malware metrics reviewed – March 2025." 09 Apr 2025
27. Verity471 Intelligence Bulletin. "Malware metrics reviewed – May 2025." 04 Jun 2025
28. Verity471 Intelligence Bulletin. "Malware metrics reviewed – July 2025." 06 Aug 2025
29. Verity471 Intelligence Bulletin. "Malware metrics reviewed – September 2025." 08 Oct 2025
30. Verity471 Intelligence Bulletin. "Malware metrics reviewed – October 2025." 07 Nov 2025
31. Verity471 Intelligence Bulletin. "Rhadamanthys, VenomRAT, Elysium malware families disrupted in Operation Endgame." 13 Nov 2025
32. Verity471 Underground Perspective. "Node package manager supply chain attack dubbed Shai-Hulud compromises hundreds of packages." 19 Sep 2025
33. Verity471 Malware Campaign. "Node package manager packages compromised in Shai-Hulud 2.0 campaign." 28 Nov 2025
34. Verity471 Malware Campaign. "Cracked software lures deliver information stealers to Windows, macOS via ClickFix attacks." 26 Jun 2025
35. Verity471 Malware Campaign. "Actor leverages Cloudflare ClickFix technique to distribute multiple malware strains." 28 Aug 2025
36. Verity471 Information Report. "Actor offers malware for ClickFix social-engineering attacks, reveals operational details." 03 Aug 2025
37. Verity471 Information Report. "Actor offers phishing project to deliver malware via ClickFix social-engineering technique." 11 Aug 2025
38. Verity471 Information Report. "Actor offers phishing kits to harvest account credentials, deliver malware, leverages ClickFix social-engineering technique." 06 Oct 2025

39. Verity471 Information Report. "Actor offers VulnCloudFlare phishing kit, leverages ClickFix social-engineering technique." 27 Aug 2025
40. Verity471 Information Report. "Actor offers phishing pages exploiting ClickFix social-engineering technique for malware delivery." 10 Dec 2025
41. Verity471 Information Report. "Actor offers to sell Google Meet, Zoom video-conferencing platform phishing toolkits, leverages ClickFix social-engineering technique." 06 Oct 2025
42. Verity471 Information Report. "Actor offers brute-forcing tools, malicious development service, phishing pages." 11 Dec 2025
43. X, @MehdiFarooq2. <https://x.com/MehdiFarooq2/status/1935502598221533185>. 19 Jun 2025
44. Verity471 Whitepaper. "Phishing Landscape Review." 24 Dec 2025
45. Verity471 Underground Perspective. "Threat actors exploit CVE-2025-5777 aka CitrixBleed 2 vulnerability impacting Citrix NetScaler application delivery controller to gain initial access." 08 Jul 2025
46. Verity471 Underground Perspective "Microsoft SharePoint zero-day remote code execution vulnerabilities exploited." 21 Jul 2025
47. Verity471 Underground Perspective. "CVE-2025-55182 aka React2Shell vulnerability widely exploited in wild, public exploit tested to obtain remote code execution." 09 Dec 2025
48. Verity471 Underground Perspective. "Operation Eastwood impacts pro-Russian cybercrime network NoName057(16)." 17 Jul 2025
49. Verity471 Instant Messaging Thread. 17 Jul 2025
50. Verity471 Instant Messaging Thread. 23 Jul 2025
51. Verity471 Instant Messaging Thread. 13 Dec 2025
52. Verity471 Instant Messaging Thread. 15 Jan 2025
53. Verity471 Instant Messaging Thread. 23 Jul 2025
54. Verity471 Instant Messaging Thread. 27 Jul 2025
55. Verity471 Instant Messaging Thread. 24 Jul 2025
56. Verity471 Instant Messaging Thread. 13 Oct 2025
57. Verity471 Information Report. "Members of BL4CK CYB3R hacktivist group launch distributed denial-of-service attacks targeting Thailand-based entities following Cambodia border shooting." 28 Jun 2025

- 58. Verity471 Information Report. "Pro-Cambodia hacktivist group members launch cyber campaign targeting Thailand-based entities in response to Cambodia-Thailand conflict." 25 Aug 2025
- 59. Verity471 Instant Messaging Thread. 29 Oct 2025
- 60. Verity471 Instant Messaging Thread. 30 Oct 2025
- 61. Verity471 Breach Alert. 18 Jul 2025
- 62. Verity471 Breach Alert. 14 May 2025
- 63. Verity471 Breach Alert. 11 Mar 2025
- 64. Verity471 Breach Alert. 17 Nov 2025
- 65. Verity471 Instant Messaging Thread. 31 Oct 2025

About Intel 471

Intel 471 equips enterprises and government agencies with intelligence-driven security offerings powered by real-time insights into cyber adversaries, threat patterns, and potential attacks relevant to their operations. By integrating human-sourced intelligence with advanced automation and curation, the company's platform enhances security measures and enables teams to bolster their security posture by prioritizing controls and detections based on real-time cyber threats. Organizations are empowered to neutralize and mitigate digital risks across dozens of use cases across our solution portfolios: Cyber Threat Exposure, Cyber Threat Intelligence, and Cyber Threat Hunting.

Learn more at www.intel471.com

Our customers' eyes and ears outside the wire.



NOTES



intel471



intel471Inc



intel471Inc



intel471



intel471_Inc



1209 N Orange St, Wilmington, DE 19801

No part of this report should be reproduced in any way without explicit permission of Intel 471, Inc.

© Intel 471 Inc. All rights reserved.